

ALLGEMEINES KI-IT-SICHERHEITSKONZEPT

Unternehmensintegrierte KI mit bevorzugter lokaler Inferenz

ÖFFENTLICH – organisationsneutrale Referenzvorlage

Version 0.2.0 · Fachlicher Stichtag 14.09.2026

Dokumentenlenkung

Merkmal	Festlegung
Dokumenttitel	Allgemeines KI-IT-Sicherheitskonzept
Dokumentstatus	ÖFFENTLICH – organisationsneutrale Referenzvorlage
Version	0.2.0
Fachlicher Stichtag	14.09.2026
Normative Anforderungen	KI-IT-Sicherheitskatalog nach Open Security Controls Assessment Language (OSCAL) 1.1.3
OSCAL-Fassung	1.1.3
Betriebsmodell	Unternehmensintegriert; lokale Inferenz bevorzugt; externe KI nur mit zusätzlicher Freigabe
Modelländerung	Training und Feinabstimmung ausgeschlossen

Inhaltsverzeichnis

1 Dokumentenstatus und Geltungsbereich.....	4
2 Zweck, Zielgruppe und Abgrenzung	5
2.1 Zentrale Begriffe	5
3 Voraussetzungen des allgemeinen IT-Sicherheitskonzepts	6
4 Unternehmensintegrierte KI-Systemarchitektur	7
5 Systemgrenzen, Vertrauenszonen und Datenflüsse	8
5.1 Kommunikations- und Importregeln	8
6 Rechts-, Normen- und Anwendbarkeitsmatrix.....	10
7 Steuerung, Rollen und Verantwortlichkeiten.....	11
8 KI-Risiko- und Bedrohungsmodell.....	12
8.1 Bewertungsverfahren	12
8.2 Bewertungsmaßstab und Freigabegrenzen	13
8.3 Risikoregister der Standardarchitektur	14
9 KI-spezifische Sicherheitsmaßnahmen.....	18
9.1 Geltungsbereich und Abhängigkeit vom Basis-Sicherheitskonzept.....	18
9.2 KI-Steuerung, Inventar, Rollen und Nutzungsgenehmigung	20
9.3 Recht, Datenschutz, Mitbestimmung, Schutzbedarf und Geheimschutzfreigaben.....	23
9.4 Lokale Systemarchitektur und Vertrauensgrenzen	25
9.5 Container-, Inferenz- und API-Sicherheit.....	27
9.6 Modellbeschaffung, Herkunftsnachweis, Integrität und Austausch	31
9.7 Ausdrückliches Trainings- und Feinabstimmungsverbot.....	33
9.8 Sicherheit der lokalen Wissenssuche, Suchvektoren und Dateibernahmen	34
9.9 Identitäten, Rollen, technische Konten und Geheimnisse	39
9.10 Chat-Oberflächen und agentische Clientanwendungen	40
9.11 Eingeschleuste Anweisungen, Datenabfluss und unsichere Modellausgaben	42
9.12 Werkzeugnutzung, Dateizugriff und Befehlsausführung.....	44
9.13 Gezielte Angriffe, Modellmissbrauch und Ressourcenerschöpfung	46
9.14 Bewertung, Freigabe, Wiederholungsprüfung und Rückkehr zur Vorversion	48
9.15 Protokollierung, Überwachung, Verhaltensänderungen, Vorfälle und Wiederanlauf	50
9.16 Außerbetriebnahme und nachweisbare Löschung	53
9.17 Bedingte Anforderungen für externe Inferenz	54
9.18 Nachweise, Ausnahmen und akzeptierte Restrisiken	57
10 Wissenssuche, persönliche Speicherung und Beiträge	58
11 Agentische Anwendungen und lokale Entwicklungsumgebungen	61
12 Betrieb, Änderung, Modellwechsel, Vorfälle und Außerbetriebnahme	64
13 Nachweis-, Prüf- und Zuordnungsübersicht	65
14 Quellenverzeichnis und Abkürzungen.....	69
14.1 Quellenverzeichnis	69
14.2 Abkürzungen	73

1 Dokumentenstatus und Geltungsbereich

Das Konzept trägt den Status ÖFFENTLICH – organisationsneutrale Referenzvorlage. Es gilt für eine in die Unternehmensumgebung eingebundene generative KI mit verwalteten Clients und kontrollierten Zugängen. Lokale Inferenz wird bevorzugt; bestehende Unternehmensdienste werden nach dem allgemeinen IT-Sicherheitskonzept genutzt. Externe KI benötigt eine zusätzliche ausdrückliche Freigabe.

Der Status ÖFFENTLICH gilt nur für die organisationsneutrale Fassung. Sobald reale Organisations-, Infrastruktur-, Schutzbedarfs-, Konto- oder Schwachstelleninformationen aufgenommen werden, ist die Fassung getrennt zu führen, angemessen zu schützen und durch die zuständigen Stellen einzustufen und freizugeben.

2 Zweck, Zielgruppe und Abgrenzung

Dieses Sicherheitskonzept regelt Planung, Freigabe, Betrieb, Änderung und Außerbetriebnahme generativer KI-Dienste. Es richtet sich an Leitung, Informationssicherheit, Datenschutz, Recht, Geheimschutz, Personalvertretung und Fachverantwortung sowie an Rollen für Architektur, Plattform, Netzwerk, Identität, Wissenssuche, Modelle, Tests und Betrieb.

Training, Feinabstimmung und selbsttätige Änderungen produktiver Modellgewichte sind ausgeschlossen. Fachwissen bleibt außerhalb der Modellgewichte und kann aus freigegebenen Beständen oder persönlichen Arbeitsunterlagen stammen. Freiwillige Beiträge aus Agentenarbeit können einen Unternehmenswissensbestand ergänzen, sofern Zweck, Zustimmung und Rechte dies erlauben. Jede betriebliche Tätigkeit bleibt auch bei längerem KI-Ausfall ohne KI möglich.

2.1 Zentrale Begriffe

Lokale Inferenz: Ausführung eines vortrainierten Modells innerhalb der eigenen Infrastruktur, ohne beabsichtigte Änderung der Modellgewichte.

Wissenssuche (RAG): Suche nach berechtigten Textausschnitten, die einem freigegebenen Modell als zusätzlicher Kontext übergeben werden; dies verändert keine Modellgewichte.

Suchvektor (Embedding): Numerische Darstellung eines Inhalts für die Ähnlichkeitssuche. Der Schutzbedarf der Quelldaten kann darin erhalten bleiben.

Bedarfsgesteuerte Dateiübernahme: Übergabe einer Datei für die aktuelle Aufgabe. Persönliche Speicherung folgt den normalen Unternehmensregeln; die Übernahme in Unternehmenswissen ist davon getrennt.

Programmierschnittstelle (API): Technischer Zugang, über den ein Client festgelegte Funktionen eines Dienstes aufruft.

Identitätsdienst (IdP): Unternehmensdienst, der Personen und technische Konten verlässlich identifiziert und deren Anmeldung unterstützt; er kann lokal oder als freigegebener externer Dienst betrieben werden.

Transportverschlüsselung (TLS): Verschlüsselung einer Netzwerkverbindung zum Schutz vor Mitlesen und Veränderung während der Übertragung.

Zentrale Sicherheitsauswertung (SIEM): Geschützte Sammlung und Auswertung sicherheitsrelevanter Protokollereignisse nach den Unternehmensregeln.

Model Context Protocol (MCP): Technisches Protokoll zur Anbindung zusätzlicher Werkzeuge oder Datenquellen an eine agentische Anwendung.

Agentische Anwendung: Client oder Dienst, der einen Modellvorschlag in einen Datei-, Werkzeug-, Befehls- oder Netzwerkzugriff überführen kann.

Eingeschleuste Anweisung (Prompt Injection): Anweisung in einer Eingabe, einem Dokument oder einer Werkzeugausgabe, die festgelegte Regeln oder Berechtigungsgrenzen umgehen soll.

Herkunftsnachweis: Nachvollziehbare Kette von der veröffentlichten Quelle eines Modells, Pakets oder Dokuments bis zum tatsächlich verwendeten Artefakt.

Ausgehende Verbindung: Netzwerkverbindung aus der KI-Umgebung zu einem Ziel außerhalb der freigegebenen lokalen Systemgrenze.

Zugriffsregel (ACL): Technische Liste, die festlegt, welche Identität auf welche Daten oder Funktionen zugreifen darf.

Restrisiko: Risiko, das nach Umsetzung und Prüfung der vorgesehenen Sicherheitsmaßnahmen verbleibt.

3 Voraussetzungen des allgemeinen IT-Sicherheitskonzepts

Der sichere KI-Betrieb setzt ein wirksames allgemeines IT-Sicherheitskonzept und einen festgelegten Informationsverbund voraus. Die KI-spezifischen Maßnahmen ergänzen diesen Sicherheitsprozess dort, wo Modelle, Wissensbestände, Eingaben oder automatisierte Werkzeugzugriffe zusätzliche Risiken erzeugen:¹

- Verwaltete Clients und Server, vorhandene Unternehmensanmeldung, Rollen und Multifaktorauthentisierung (MFA) gemäß Unternehmensvorgaben.
- Vertrauenswürdige Zertifikate, Transportverschlüsselung, Segmentierung, Firewalls und abgesicherter Fernzugriff gemäß IT-Sicherheitskonzept.
- Patch-, Schwachstellen-, Konfigurations- und sichere Softwareverteilung.
- Bestehende Protokollierung, Überwachung, Datensicherung, Reparatur, Vorfallbehandlung und Schadsoftwareschutz.
- Normale Dokumentenfreigabe, Qualitätssicherung und Konfigurationsverwaltung einschließlich freigegebener Bereiche für KI-Wissensarbeit.

Fehlende Basismaßnahmen sperren die Freigabe der abhängigen KI-Funktion. Sie werden im allgemeinen Sicherheitsprozess behandelt und nicht durch KI-spezifische Einzelmaßnahmen ersetzt.

¹ Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschutz-Methodik, Version 1.0, Stand Oktober 2017, S. 11, S. 69–74 und S. 154–156, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_2.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

4 Unternehmensintegrierte KI-Systemarchitektur

Verwaltete Clients nutzen freigegebene KI-Zugänge mit vertrauenswürdiger Unternehmensanmeldung. Zentrale lokale Inferenz und Wissenssuche laufen in angemessen getrennten Betriebsbereichen. Alternativ ist verwaltete lokale Ausführung auf dem Endgerät mit gleichwertigen Zugriffsregeln möglich. Container sind eine mögliche Betriebsform. Fernzugriff und Transportverschlüsselung folgen dem allgemeinen IT-Sicherheitskonzept.

Vorhandene Identitätsdienste, Git- und Datenablagen sowie Betriebsdienste dürfen integriert werden. Eine zusätzliche KI-Anmeldung entfällt bei verlässlich übernommenem Identitätskontext; reine Netzwerkzugehörigkeit genügt nicht. Direkte Modell- und Verwaltungsschnittstellen dürfen diese Grenzen nicht umgehen. Externe Inferenz ist standardmäßig aus und nur innerhalb einer zusätzlichen KI-Freigabe zulässig (Abbildung 1).

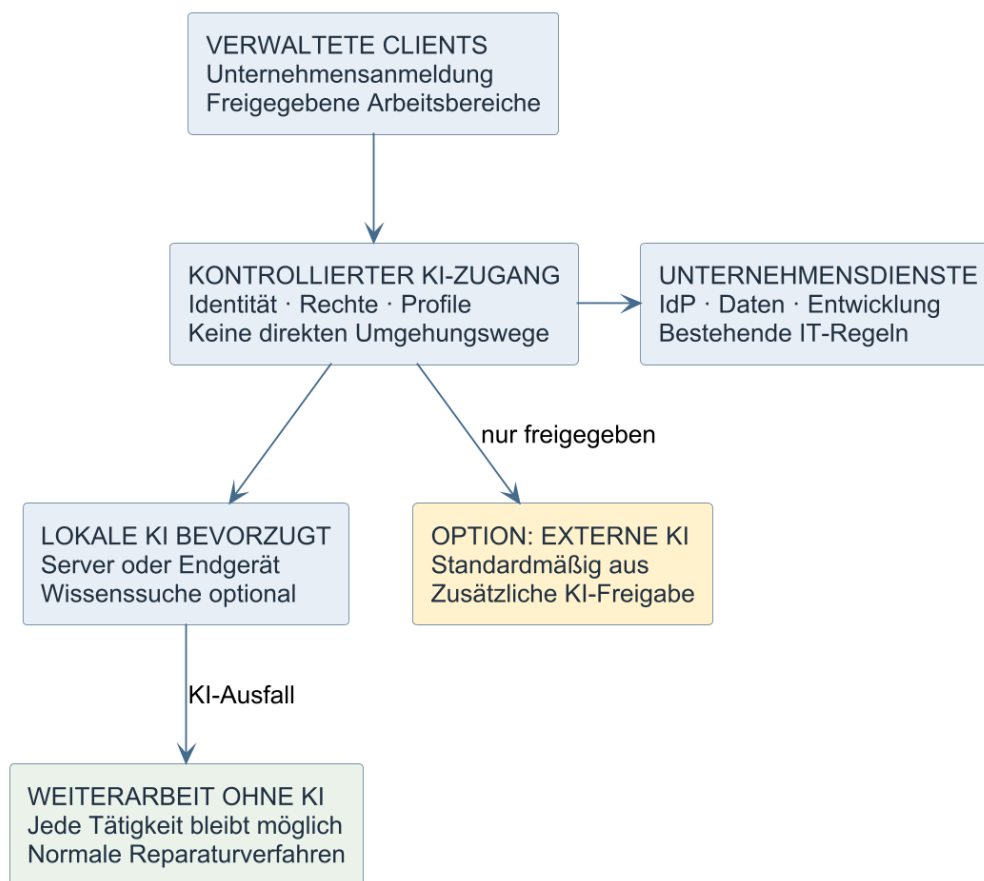


Abbildung 1: Kontrollierte KI-Zugänge verbinden verwaltete Clients mit freigegebenen Modellen und Unternehmensdiensten.

5 Systemgrenzen, Vertrauenszonen und Datenflüsse

Jede Vertrauenszone besitzt eine klar abgegrenzte Aufgabe. Übergänge zwischen den Zonen werden authentisiert, protokolliert und auf die ausdrücklich freigegebenen Kommunikationsbeziehungen begrenzt.

Vertrauenszone	Aufgabe und Grenze
Verwaltete Clientzone	Benutzerinteraktion, lokale Entwicklungswerkzeuge und begrenzte agentische Aktionen.
Kontrollierter KI-Zugang	Freigegebene Anfragepfade; Identität, Rollen, Transportverschlüsselung sowie Modell-, Kontext-, Raten- und Werkzeugregeln.
KI-Betriebsbereich	Lokale Inferenz-, Wissens- und Datendienste mit begrenzten Schnittstellen; zentrale Server oder gleichwertig geschützte lokale Ausführung.
Importweg	Prüfung von Modellen, Containerabbildern, Paketen und Erweiterungen vor der Übernahme in lokale Registrierungen.
Betriebs- und Nachweisbereich	Besonders geschützte Protokolle, Sicherheitsauswertungen, Freigaben, Sicherungen und Wiederherstellungsdaten.

5.1 Kommunikations- und Importregeln

Ein internes Container- oder Pod-Netz ist keine ausreichende Sicherheitsgrenze. Kommunikationsbeziehungen werden standardmäßig verweigert und einzeln erlaubt. Inferenz-, Administrations-, Diagnose-, Metrik-, Cluster- und Zwischenspeicher-Schnittstellen bleiben vom normalen Netz getrennt.

Verarbeitungsorte, freigegebene Ziele und Datenarten werden nach dem IT-Sicherheitskonzept festgelegt. Eine Internet- oder IdP-Freigabe erlaubt noch keine externe KI. Lokal eingesetzte Modelle, Pakete und Erweiterungen durchlaufen die vorhandenen Software- und Importprüfungen; ihre Herkunft und Integrität bleiben nachvollziehbar (Abbildung 2).

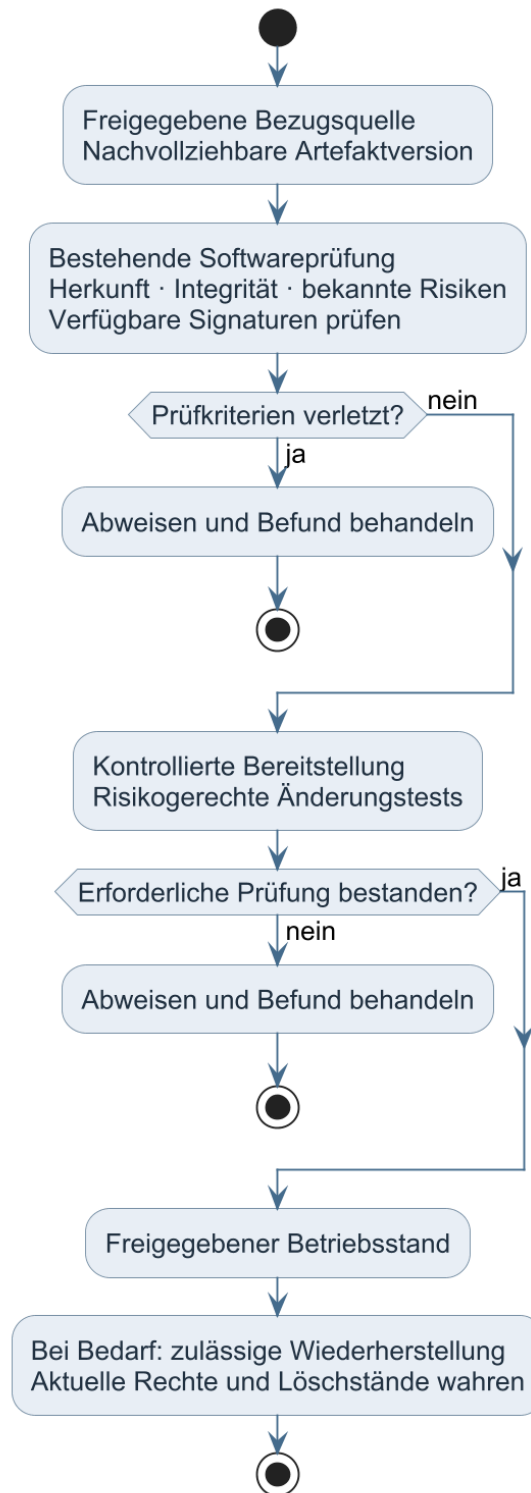


Abbildung 2: Artefakte durchlaufen bestehende Softwareprüfungen und eine ihrem Änderungsrisiko entsprechende Freigabe.

6 Rechts-, Normen- und Anwendbarkeitsmatrix

Vor der Freigabe eines Anwendungsfalls bestimmen die zuständigen Funktionen die anwendbaren Rechtsgrundlagen, Beteiligungsrechte, behördlichen Vorgaben und Freigabebedingungen. Die Ergebnisse werden als technische oder organisatorische Bedingungen umgesetzt.

Grundlage	Anwendbarkeit	Prüf- und Festlegungsbedarf	Quellen
KI-Verordnung (EU) 2024/1689	Anwendungsfallbezogen	Rolle, Risikoklasse, Betreiberpflichten, KI-Kompetenz und Folgenabschätzung prüfen.	Q-EU-001
Datenschutzrecht	Bei personenbezogenen Daten	Rechtsgrundlage, Zweck, Minimierung, Rollen, Transparenz, Rechte, Löschung und Folgenabschätzung prüfen.	Q-BFDI-001; Q-DSK-001 bis Q-DSK-003
BSIG und adressatenbezogene BSI-Vorgaben	Organisationsspezifisch	Adressat, Verbindlichkeit, Basis-Sicherheitskonzept und Nachweispflichten feststellen.	Q-BSIG-001; Q-BSI-001
Geheimschutz	Bei entsprechend geschützten Inhalten	Verarbeitung nur nach befugter Einstufung, Systemzulässigkeit und ausdrücklicher Freigabe.	Q-SUEG-001; Q-VSA-001
ISO/IEC 27001 und 27002	Orientierende Zuordnung	Lizenzierte Normtexte und unabhängige Bewertung für eine Konformitätsaussage erforderlich.	Q-ISO-27001; Q-ISO-27002
ISO/IEC 42001, 23894, 42005, 5338, 5259, 25059	Orientierende KI-Zuordnung	Nur öffentliche Metadaten und Kennungen; keine Wiedergabe proprietärer Anforderungen.	Q-ISO-42001; Q-ISO-23894; Q-ISO-42005; Q-ISO-5338; Q-ISO-5259; Q-ISO-25059

7 Steuerung, Rollen und Verantwortlichkeiten

Entscheidungs-, Umsetzungs- und Prüffunktionen werden so getrennt, dass Freigaben und wesentliche Restrisiken nachvollziehbar verantwortet werden. Eine Person darf mehrere Rollen wahrnehmen, sofern Interessenkonflikte behandelt und notwendige unabhängige Prüfungen erhalten bleiben.

Rolle	Kernverantwortung
Leitung	Risikobereitschaft, Ressourcen, wesentliche Restrisiken und Freigabeframework.
KI-Verantwortliche	Inventar, Anwendungsfälle, Modell- und Richtlinienfreigaben sowie koordinierter Lebenszyklus.
Informationssicherheit	Bedrohungsmodell, Kontrollanforderungen, Prüfung, Vorfälle und Basis-ISMS-Verknüpfung.
Datenschutz, Recht, Geheimschutz, Personalvertretung	Anwendbarkeitsprüfung, Beteiligung, Bedingungen und befugte Freigaben im jeweiligen Zuständigkeitsbereich.
Architektur, Netz, Plattform, Identität und KI-Zugang	Technische Zonen, ausgehender Netzwerkverkehr, freigegebener Laufzeitstand, Identitäten, Zertifikate und Richtliniendurchsetzung.
Modell, Wissenssuche, Daten und Werkzeuge	Herkunftsnachweis, Integrität, Zugriffsregeln, Löschung, Erweiterungsfreigabe und fachliche Datenverantwortung.
Test und Betrieb	Reproduzierbare Bewertung, Wiederholungsprüfung, Überwachung, Protokollierung, Wiederanlauf und Außerbetriebnahme.
Nutzende	Zweckgebundene Nutzung, Schutzregeln, Ergebnisprüfung und Meldung von Auffälligkeiten.

8 KI-Risiko- und Bedrohungsmodell

8.1 Bewertungsverfahren

Die Einstufungen sind begründete Planungsbewertungen der beschriebenen Nutzung, keine gemessenen Häufigkeiten oder Nachweise einer realen Unternehmensumsetzung. Ausgangsrisiken berücksichtigen die allgemeinen IT-Basismaßnahmen vor den zusätzlich genannten KI-Kontrollen; Restrisiken setzen deren vollständige, wirksame Umsetzung und die jeweiligen Annahmen voraus. Selten bezeichnet weniger als einmal in fünf Jahren, mittel einmal in fünf Jahren bis einmal jährlich, häufig mehr als einmal jährlich bis einmal monatlich und sehr häufig mehr als einmal monatlich je betrachteter KI-Umgebung. Bewertet wird das schädliche Szenario, nicht jede fehlerhafte Modellantwort. Vernachlässigbarer Schaden hat kaum betriebliche Folgen; begrenzter Schaden verursacht beherrschbare Mehrarbeit innerhalb der Mindestanforderungen; beträchtlicher Schaden umfasst erhebliche Daten-, Qualitäts- oder Betriebsschäden; existenzbedrohender Schaden gefährdet den Fortbestand. Die Matrix ordnet diese Ausprägungen den Risikokategorien zu. Abweichende Schutzbedarfe, fehlende Maßnahmen oder neue Erkenntnisse erfordern eine erneute Bewertung. Die Kategorien allein ersetzen keine begründete Risikoakzeptanz.²

Die Bewertung erfasst Eingaben, Modelle, Systemanweisungen, Wissenssuche, Werkzeuge, Clients, Schnittstellen, Plattform, Protokolle und Importwege. Wesentliche Änderungen, Vorfälle, neue Erkenntnisse oder erreichte Prüftermine führen zur erneuten Bewertung der betroffenen Risiken (Abbildung 3).

² Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7, S. 26–28 und S. 33–35, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschatz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

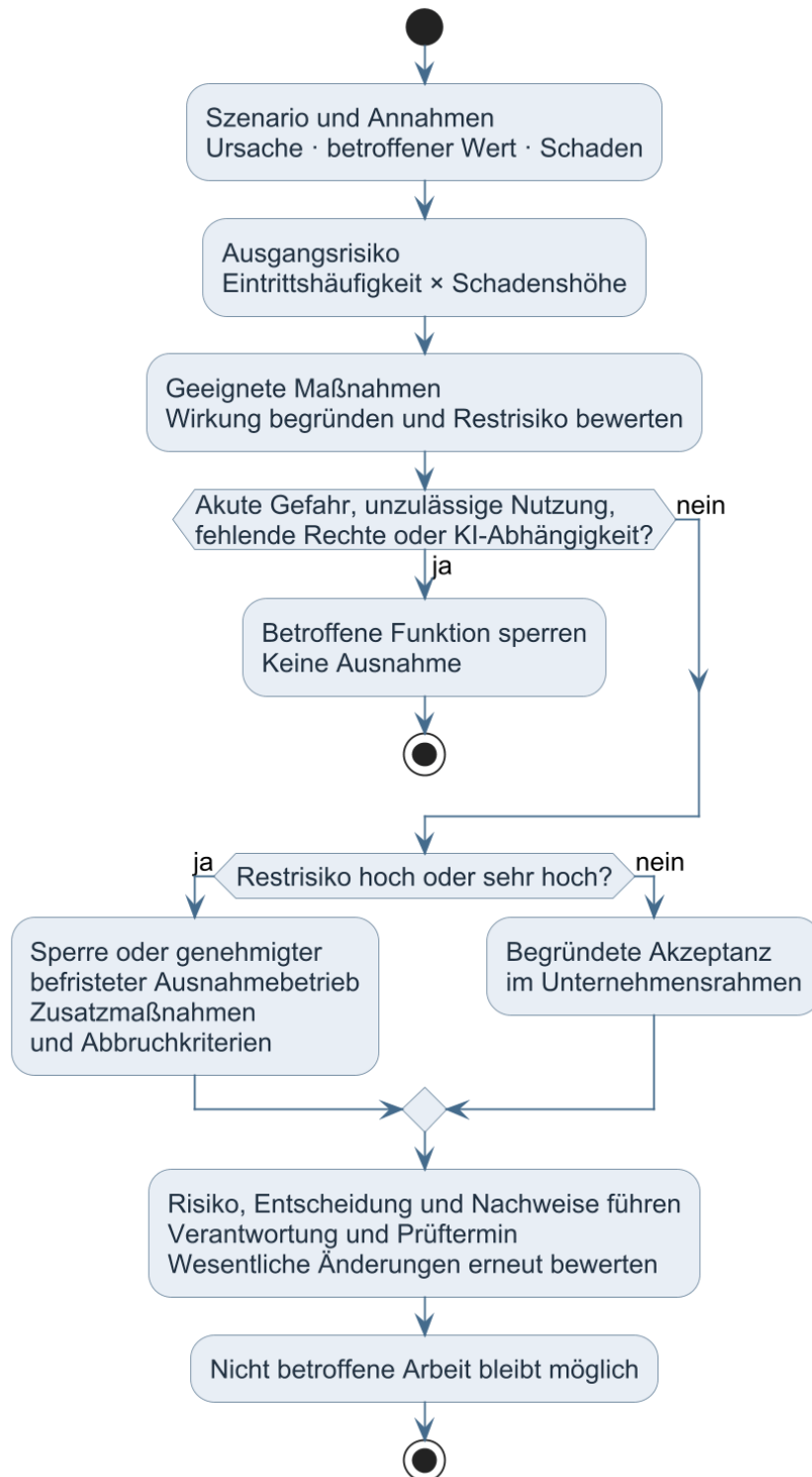


Abbildung 3: Risiken werden szenariobezogen behandelt und bis zur Freigabe erneut bewertet.

8.2 Bewertungsmaßstab und Freigabegrenzen

Die Eintrittshäufigkeit wird als selten, mittel, häufig oder sehr häufig eingestuft. Die Schadenshöhe wird als vernachlässigbar, begrenzt, beträchtlich oder existenzbedrohend bewertet. Die Kombination ergibt die Risikokategorie gering, mittel, hoch oder sehr hoch. Jede Matrixzelle nennt die Kategorie als Text; die Farbe dient nur der schnellen Orientierung.

Schadenshöhe / Eintrittshäufigkeit	selten	mittel	häufig	sehr häufig
existenzbedrohend	mittel R: R-08	hoch A: R-08	sehr hoch	sehr hoch
beträchtlich	mittel R: R-01 R: R-02 R: R-03 R: R-04 R: R-05	mittel A: R-02 A: R-04 R: R-07 R: R-09	hoch A: R-01 A: R-03 A: R-05 A: R-06 A: R-07 A: R-09	sehr hoch
begrenzt	gering	gering R: R-06	mittel	hoch
vernachlässigbar	gering	gering	gering	gering

A = Ausgangsrisiko vor zusätzlichen KI-Kontrollen
R = Restrisiko unter den dokumentierten Umsetzungsannahmen
Planungsbewertung; keine allgemeine Wirksamkeitsgarantie.

Abbildung 4: Ausgangs- und Restrisiken gelten unter den dokumentierten Umsetzungsannahmen.

- Geringe Risiken dürfen durch die zuständige Rolle akzeptiert und überwacht werden.
- Mittlere Restrisiken dürfen mit Begründung, Verantwortung und Prüftermin innerhalb der Unternehmensvorgaben akzeptiert werden; die Kategorie allein verlangt keinen zusätzlichen Maßnahmenplan oder pauschale Befristung.
- Hohe und sehr hohe Restrisiken sperren die betroffenen Funktionen, sofern kein ausdrücklich genehmigter, befristeter Betrieb mit zusätzlichen Maßnahmen, Überwachung und Abbruchkriterien zulässig ist.
- Akute Gefahren, unzulässige Verarbeitung, fehlende Berechtigungen und unverzichtbare KI-Abhängigkeiten erlauben keine Ausnahme. Nicht betroffene Arbeit bleibt möglich.
- Jede Akzeptanz nennt Begründung, Verantwortung, Prüftermin und erneuten Bewertungsanlass; Befristungen folgen der Risikostufe, den Unternehmensregeln und der Entscheidung. Existenzbedrohende Folgen werden ausdrücklich auf zuständiger Leitungsebene behandelt.

8.3 Risikoregister der Standardarchitektur

Die Risikobewertung wird vor der Erstnutzung, mindestens jährlich sowie nach wesentlichen Änderungen, Sicherheitsvorfällen oder neuen Erkenntnissen wiederholt. Die folgende Bewertung gilt für die in diesem Konzept festgelegte Standardarchitektur und die vollständige Umsetzung der genannten Kontrollen.

ID	Risikoszenario	Ausgangsrisiko → Restrisiko	Behandlung und Kontrollen
R-01	Eine eingeschleuste Anweisung löst eine nicht erlaubte Werkzeugaktion aus.	häufig × beträchtlich = hoch → selten × beträchtlich = mittel	Aufgaben- und Kontexttrennung, unabhängig durchgesetzte Werkzeugprofile, konkrete Zustimmung für nicht beherrschbare Wirkungen und praktisch nutzbare Wiederherstellung. KI-PMT-001, KI-TOL-001, KI-AGT-001, KI-THR-001
R-02	Ein manipuliertes Modell, Containerabbild oder Paket wird übernommen.	mittel × beträchtlich = mittel → selten × beträchtlich = mittel	Kontrollierte Bezugsquellen, Herkunfts- und Integritätsprüfung sowie angemessene Software- und Änderungsfreigabe. KI-MOD-001, KI-TOL-002, KI-VAL-002
R-03	Ein Wissensbestand oder eine Zusammenfassung legt geschützte Personal- oder Kundendaten unberechtigten Personen offen.	häufig × beträchtlich = hoch → selten × beträchtlich = mittel	Berechtigungsprüfung bei Aufnahme und Abfrage, sichere Ableitungen, standardmäßig ausgeschaltete persönliche Wissensbeiträge und wirksame Sperr- und Löschwege. KI-RAG-002, KI-RAG-003, KI-RAG-004, KI-REC-001
R-04	Eine direkte KI-Schnittstelle oder ein ungültiger Identitätskontext umgeht Zugriffsregeln.	mittel × beträchtlich = mittel → selten × beträchtlich = mittel	Vertrauenswürdige Unternehmensanmeldung, individuelle Rollenprüfung und Schutz sämtlicher inventarisierter Nutzungs- und Verwaltungszugänge. KI-API-001, KI-ARC-001, KI-IAM-001
R-05	Protokolle speichern und verbreiten unnötig schutzbedürftige Inhalte.	häufig × beträchtlich = hoch → selten × beträchtlich = mittel	Datensparsame Sicherheitsmetadaten, getrennte persönliche Verläufe, geschützte Auswertung und geregelte Aufbewahrung. KI-OPS-001, KI-RAG-004, KI-REC-002
R-06	KI-Überlastung oder fehlender Modellzugang behindert unterstützte betriebliche Tätigkeiten.	häufig × beträchtlich = hoch → mittel × begrenzt = gering	Ressourcengrenzen und Isolation schützen die übrige IT; sämtliche Tätigkeiten, Datenzugänge und Mindestanforderungen bleiben ohne KI durchführbar. KI-GOV-002, KI-THR-002, KI-OPS-003

ID	Risikoszenario	Ausgangsrisiko → Restrisiko	Behandlung und Kontrollen
R-07	Unzutreffende oder unsichere Ausgaben führen zu schädlichen Entscheidungen oder Codeänderungen.	häufig × beträchtlich = hoch → mittel × beträchtlich = mittel	Bestehende fachliche Qualitätssicherung, sichere Weiterverarbeitung, risikogerechte menschliche Entscheidungen und wiederholte Eignungstests. KI-OUT-001, KI-VAL-001, KI-TOL-001
R-08	Ein nicht freigegebener KI-Zielwechsel überträgt besonders schutzbedürftige Daten nach außen.	mittel × existenzbedrohend = hoch → selten × existenzbedrohend = mittel	Explizite KI-Nutzungsfreigaben, begrenzte Datenflüsse und ausschließlich bereits freigegebene Ausweichziele. KI-EXT-001, KI-EXT-002, KI-ARC-002
R-09	Ein Modell- oder Versionswechsel verschlechtert Sicherheit oder Ergebnisqualität.	häufig × beträchtlich = hoch → mittel × beträchtlich = mittel	Nachvollziehbare Modellstände, risikobasierte Änderungsprüfung, wiederholte Bewertungen und Abschaltung oder zulässige Wiederherstellung. KI-MOD-002, KI-VAL-001, KI-VAL-002, KI-OPS-003

R-01 – Annahmen und verbleibendes Risiko

Routineprofile, Grenzen und Wiederherstellung sind eingerichtet und geprüft. Ein bloßer Hinweis an das Modell genügt nicht.

Mehrere unabhängige Schranken machen eine erfolgreiche unzulässige Aktion selten; verbleibende Fehlkonfiguration oder Umgehung kann weiterhin beträchtlich schaden.

R-02 – Annahmen und verbleibendes Risiko

Die vorgesehenen Importprüfungen werden tatsächlich durchgeführt; verfügbare Signaturen werden geprüft.

Ungeprüfte oder veränderte Artefakte werden abgefangen. Eine kompromittierte vertrauenswürdige Quelle bleibt möglich; Prüfsummen verhindern diesen Schaden nicht.

R-03 – Annahmen und verbleibendes Risiko

Der gesamte Such- und Beitragsweg setzt Rechte unabhängig vom Modell durch. Persönliche Beiträge sind nur mit sichtbarer Zustimmung und unveränderten Schutzgrenzen aktiv.

Automatische Rechteausweitung und stille Beiträge werden verhindert. Zuordnungs- oder Konfigurationsfehler bleiben möglich und können trotz geringer Eintrittshäufigkeit erheblichen Datenschutzschaden verursachen.

R-04 – Annahmen und verbleibendes Risiko

Der Identitätskontext wird geprüft, direkte Endpunkte sind begrenzt und Nutzerzugriffe bleiben individuell sperrbar.

Unangemeldete und unberechtigte Zugriffe werden regulär abgewiesen; Fehler an Schnittstellen oder Identitätsbindungen sind nicht vollständig ausgeschlossen.

R-05 – Annahmen und verbleibendes Risiko

Inhaltsprotokollierung ist auf begründete Zwecke beschränkt; Logs werden nicht als Unternehmenswissen übernommen.

Minimierung reduziert die Offenlegungswahrscheinlichkeit. Bei Fehlkonfiguration können weiterhin sensible Inhalte mit beträchtlichen Folgen betroffen sein.

R-06 – Annahmen und verbleibendes Risiko

KI ist in keinem Arbeitsschritt unverzichtbar. Benötigte Kenntnisse und Anwendungen sind ohne KI verfügbar. Ressourcenisolation ist wirksam; die Fortführung ist geprüft.

Eine KI-Störung bleibt möglich, verursacht unter diesen Voraussetzungen aber vor allem Mehrarbeit und Verzögerung. Die geringere Schadenshöhe beruht auf KI-unabhängiger Arbeit, nicht auf garantierter Reparaturzeit oder einem optionalen Ersatzserver.

R-07 – Annahmen und verbleibendes Risiko

Die normalen Qualitätsverfahren werden auch bei KI angewendet; kritische Entscheidungen werden fachlich geprüft.

Geprüfte Nutzung reduziert schädliche Übernahmen, beseitigt aber weder Modellfehler noch menschliche Fehlbeurteilungen. Die Schwere eines verbleibenden Fehlers sinkt dadurch nicht zwangsläufig.

R-08 – Annahmen und verbleibendes Risiko

Für dieses Szenario werden Daten mit potenziell existenzbedrohendem Offenlegungsschaden angenommen. Allgemeiner Internetzugang aktiviert keine KI-Ziele; die Zielgrenzen sind geprüft.

Fehlerhafte automatische Übertragung wird deutlich unwahrscheinlicher. Falls sie dennoch geschieht, bleibt die angenommene Schadenshöhe bestehen; Transportverschlüsselung oder ein späterer Rückgriff machen Offenlegung nicht rückgängig.

R-09 – Annahmen und verbleibendes Risiko

Änderungen werden im Unternehmensprozess behandelt; nicht fixierbare Anbieterstände sind bekannt und werden beobachtet.

Prüfungen begrenzen bekannte Rückschritte, können neue Modellfehler oder unbemerkte Anbieteränderungen jedoch übersehen. Eine Wiederherstellung verhindert nicht jeden bereits eingetretenen Schaden.

9 KI-spezifische Sicherheitsmaßnahmen

Die anwendbaren Anforderungen werden im bestehenden Unternehmensprozess umgesetzt, geprüft und mit aktuellen Nachweisen belegt. Fehlende Maßnahmen und Restrisiken sind getrennt zu behandeln; Freigabe, Akzeptanz und ein gegebenenfalls befristeter Ausnahmebetrieb richten sich nach KI-GOV-003. Bedingte Anforderungen gelten nur bei der genannten Funktion oder Betriebsform.

9.1 Geltungsbereich und Abhängigkeit vom Basis-Sicherheitskonzept

KI-GEL-001 – Abgrenzung zum allgemeinen IT-Sicherheitskonzept

Normative Anforderung

Die KI-Umgebung MUSS in den Informationsverbund und das allgemeine IT-Sicherheitskonzept eingebunden sein. Für Identitäten, Netze, Endgeräte, Dokumentenfreigabe, Qualitätssicherung, Konfigurationsmanagement, Geheimnisse, Protokollierung, Datensicherung und Vorfälle MUSS nach den dort vorgeschriebenen Maßnahmen vorgegangen werden. Dieses Konzept ergänzt ausschließlich die KI-spezifischen Risiken und Anforderungen.

Begründung

KI-Komponenten erben Risiken aus Identitätsmanagement, Netzen, Plattformen und Betrieb. Ohne nachweisbare Basis kann die Wirksamkeit der Ergänzungen nicht beurteilt werden.

Umsetzung im Geltungsbereich

Vorhandene Rollen, Freigaben, Register und Nachweise werden mit ihren Fundstellen genutzt. KI-spezifische Ergänzungen betreffen insbesondere Modellzugänge, Werkzeugwirkungen, Wissensübernahme und abgeleitete Daten. Die Freigabe eines Ordners, Repositories oder Datenbestands für KI-Wissensarbeit kann die enthaltenen Dokumente im festgelegten Zweck und Berechtigungskreis abdecken; eine zusätzliche Einzelprüfung allein wegen der KI-Nutzung ist nicht erforderlich. Bloße technische Lesbarkeit ersetzt diese Bereichsfreigabe nicht. Fehlende Basismaßnahmen werden im bestehenden Sicherheitsprozess behandelt; nur davon abhängige KI-Funktionen bleiben bis zur zulässigen Behandlung gesperrt.

Prüfziel

An ausgewählten Nutzungsfällen prüfen, ob vorhandene Unternehmensregeln einschließlich Bereichsfreigaben wirksam gelten und KI-spezifische Ergänzungen nachvollziehbar zugeordnet sind.

Erwartete Nachweise

Verweise auf geltendes IT-Sicherheitskonzept, Dokumenten- und Qualitätsprozesse; Bereichsfreigaben mit Zweck und Berechtigungskreis; Nachweise der abhängigen Basismaßnahmen.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Planung; Übernahme; Informationssicherheitsbeauftragte; KI-Verantwortliche; Systemverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: ISMS.1, ORP.1; ISO: ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1

Quellen

[Q-BSI-001] S. 4–5 und S. 11–12; [Q-BSI-2002-001] S. 11, S. 69–74 und S. 154–156; [Q-ISO-27001] öffentliche Metadaten; Zuordnung zu ISMS und Risikomanagement³

KI-GEL-002 – Schutzkennzeichnung und kontrollierte Dokumentenführung

Normative Anforderung

Konzept, Katalog und Nachweise MÜSSEN ihrem tatsächlichen Inhalt entsprechend gekennzeichnet, versioniert und zugriffsgeschützt geführt werden. Organisationsspezifische Angaben DÜRFEN nicht in die öffentliche Referenz gelangen.

Begründung

Architektur-, Schutzbedarfs- und Schwachstellenangaben können den Schutzbedarf unmittelbar erhöhen. Eine technische Zugriffsbeschränkung ersetzt weder Kennzeichnung noch informationsschutzrechtliche Freigabe.

Umsetzung im Geltungsbereich

Dokumentenlenkung, Einstufung und Freigabe folgen dem allgemeinen IT-Sicherheitskonzept und dem Konfigurationsmanagement. Öffentliche Referenz und geschützte Unternehmensfassung werden getrennt geführt; eine nicht öffentliche Kennzeichnung ersetzt keine befugte Einstufung.

Prüfziel

Nachweisen, dass Kennzeichnung, Ablage und Freigabe dem Inhalt entsprechen und ein Wechsel zu organisations- oder systemspezifischen Informationen den erforderlichen Schutzstatus wirksam auslöst.

Erwartete Nachweise

Dokumentenstatus; negative Statustests; Freigabeprotokoll; Ergebnis der automatisierten Inhaltssuche; dokumentierte Zuständigkeit für Einstufungen.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Übernahme; Freigabe; Änderung; Informationssicherheitsbeauftragte; Geheimschutzbeauftragte; Dokumentenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.1, CON.10; ISO: ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12

³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 4–5 und S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschutz-Methodik, Version 1.0, Stand Oktober 2017, S. 11, S. 69–74 und S. 154–156, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_2.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC 27001:2022, Stand ISO-Metadaten, Ausgabe 2022-10, veröffentlicht am 01.10.2022, öffentliche Metadaten; Zuordnung zu ISMS und Risikomanagement, <https://www.iso.org/standard/27001>, abgerufen am 02.09.2026.

Quellen

[Q-SUEG-001] § 4; [Q-VSA-001] allgemeine Einstufungs- und Handhabungsregeln; [Q-BMI-001] S. 26–27⁴

9.2 KI-Steuerung, Inventar, Rollen und Nutzungsgenehmigung

KI-GOV-001 – KI-Inventar und eindeutige Verantwortung

Normative Anforderung

KI-Dienste, Modelle, Clients, Datenquellen, Werkzeuge, Schnittstellen und freigegebene Nutzungen **MÜSSEN** mit verantwortlichen Rollen und Lebenszyklus im bestehenden Inventar oder einem verknüpften Register erfasst sein.

Begründung

Nicht erfasste Modelle oder Integrationen entziehen sich Risiko-, Änderungs- und Außerbetriebnahmesteuerung.

Umsetzung im Geltungsbereich

Vorhandene Asset-, Anwendungs- und Verfahrensregister werden um KI-Bezüge, Systemgrenzen und Zuständigkeiten ergänzt. Rollen können bei ausreichender Kompetenz zusammengelegt werden; notwendige unabhängige Prüfungen und Entscheidungen bleiben gewahrt. Die Dokumentation verwendet stabile Kennungen und auffindbare Fundstellen gemäß KI-ASS-001.

Prüfziel

Stichprobenartig prüfen, ob bereitgestellte Komponenten und genehmigte Nutzungen vollständig im Inventar abgebildet und Verantwortliche handlungsfähig sind.

Erwartete Nachweise

KI-Inventar; Rollenmatrix; Komponentenabgleich; Prüfprotokolle; Freigabestatus.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Planung; Beschaffung; Betrieb; Außerbetriebnahme; Leitung; KI-Verantwortliche; Systemverantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.1, OPS.1.1.2; ISO: ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3

⁴ Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023, allgemeine Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 26–27, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

Quellen

[Q-BSI-001] S. 8–10; [Q-BMVG-001] S. 24–28; [Q-EU-001] Art. 9 und 26⁵

KI-GOV-002 – Genehmigte Nutzung und KI-Kompetenz

Normative Anforderung

Zugelassene Zwecke, Datenbereiche, Werkzeuge und Entscheidungsgrenzen MÜSSEN festgelegt und den Nutzenden vermittelt werden. Jede betriebliche Tätigkeit MUSS auch bei längerem KI-Ausfall ohne KI durchführbar bleiben. Eine unverzichtbare KI-Abhängigkeit DARF nicht eingeführt werden.

Begründung

Generative KI kann überzeugend fehlerhafte Ausgaben liefern und Sicherheitsgrenzen über Eingaben oder Werkzeuge umgehen. Wirksame Regeln benötigen anwendungsbezogene Kompetenz.

Umsetzung im Geltungsbereich

Die normalen Fach-, Qualitäts- und Freigabeprozesse gelten weiter. Erforderliche Dokumente, Anwendungen, Zugänge und Kenntnisse bleiben unabhängig von KI verfügbar. Geringere Geschwindigkeit oder Qualität ist innerhalb der geltenden Mindestanforderungen zulässig. Die Weiterarbeit wartet weder auf Reparatur noch auf ein Ersatzmodell. KI-Kompetenz und der Umgang mit optionalen Wissensbeiträgen werden in bestehende Einweisungen aufgenommen.

Prüfziel

Für die unterstützten Tätigkeitsarten den Ablauf ohne KI praktisch nachvollziehen: Datenzugang, Bearbeitung, notwendige Mindestqualität und Abschluss müssen möglich bleiben. Nutzende müssen Funktions- und Freigabegrenzen erklären können.

Erwartete Nachweise

Nutzungsregeln; Einweisungsnachweise; vorhandene Prozessbeschreibungen mit Vorgehen ohne KI; Stichproben der Weiterarbeit bei abgeschaltetem KI-Zugang.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; KI-Verantwortliche; Fachverantwortliche; Personalentwicklung; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschatz: ORP.3, ORP.4; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3

Quellen

[Q-BSI-001] S. 8–10 und S. 13; [Q-BMI-001] S. 29–30; [Q-EU-001] Art. 4⁶

⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–10, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 24–28, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 9 und 26, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

KI-GOV-003 – Lebenszyklus-Risikosteuerung, Ausnahmen und Überprüfungen

Normative Anforderung

KI-Risiken MÜSSEN als Szenarien mit Eintrittshäufigkeit, Schadenshöhe, Ausgangsrisiko, Maßnahmen, begründetem Restrisiko und verantwortlicher Entscheidung bewertet werden. Geringe und mittlere Restrisiken DÜRFEN innerhalb der Unternehmensvorgaben begründet akzeptiert werden. Hohe und sehr hohe Restrisiken MÜSSEN eskaliert werden; die betroffenen Funktionen bleiben gesperrt, sofern kein ausdrücklich genehmigter, befristeter Betrieb mit zusätzlichen Schutzmaßnahmen zulässig ist. Akute Gefahren, unzulässige Verarbeitung, fehlende Berechtigungen und unverzichtbare KI-Abhängigkeiten erlauben keine Ausnahme.

Begründung

Modelle und Wissensbestände ändern Verhalten, Bedrohungsfläche und Ergebnisqualität auch ohne klassische Softwareänderung.

Umsetzung im Geltungsbereich

Der Bewertungsmaßstab und das Risikoregister dieser Kontrolle gelten für die beschriebenen Umsetzungsannahmen. Die zuständige Rolle dokumentiert Begründung, Verantwortung und Prüftermin; Befristungen richten sich bei geringen und mittleren Restrisiken nach Unternehmensvorgaben und Entscheidung. Ein mittleres Restrisiko allein verlangt keinen zusätzlichen Maßnahmenplan, wenn anwendbare Kontrollen erfüllt sind und keine weitere Maßnahme beschlossen ist. Hohe oder sehr hohe Restrisiken erfordern für jeden Ausnahmebetrieb Umfang, kompensierende Maßnahmen, befugte Entscheidung, Endtermin, Überwachung und Abbruchkriterien. Nicht betroffene Funktionen bleiben nutzbar. Die Bewertung wird vor Erstnutzung, mindestens jährlich und bei wesentlichen Änderungen, Vorfällen oder neuen Erkenntnissen überprüft; Routineänderungen folgen KI-VAL-002. Existenzbedrohende Schadensmöglichkeiten sind ausdrücklich auf zuständiger Leitungsebene zu behandeln.

Prüfziel

Szenarien und Einstufungen anhand der tatsächlichen Maßnahmeneignung und Nachweise prüfen. Akzeptierte mittlere Risiken, befristete hohe Ausnahmen und nicht ausnahmefähige Zustände anhand repräsentativer Fälle unterscheiden.

Erwartete Nachweise

Risikoregister mit Annahmen, Ausgangs- und Restrisikoeinstufung; Kontrollnachweise; Akzeptanzentscheidungen mit Verantwortlichen und Prüfterminen; gegebenenfalls befristete Ausnahmeentscheidung und Abbruchkriterien.

⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–10 und S. 13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 29–30, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 4, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; Risikoverantwortliche; KI-Verantwortliche; Informationssicherheitsbeauftragte; Leitung
Orientierende Zuordnung	BSI/IT-Grundschatz: ISMS.1, OPS.1.1.3; ISO: ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023

Quellen

[Q-BSI-001] S. 8, 10 und 12; [Q-BSI-2003-001] S. 5–7, S. 26–28 und S. 33–35; [Q-BMVG-001] S. 24–25 und S. 45–47; [Q-NIST-001] Govern-, Map-, Measure- und Manage-Aktionen⁷

9.3 Recht, Datenschutz, Mitbestimmung, Schutzbedarf und Geheimschutzfreigaben

KI-REC-001 – Rechts- und Datenschutzprüfung je Anwendungsfall

Normative Anforderung

Die Nutzung MUSS durch die geltenden Rechtsgrundlagen, Zwecke, Datenschutz-, Beteiligungs- und Unternehmensvorgaben gedeckt sein. Vorhandene Freigaben DÜRFEN für gleiche Zwecke, Datenarten und Empfängerkreise genutzt werden; zusätzliche KI-spezifische Bedingungen MÜSSEN ergänzt werden. Eine Zustimmung zu Wissensbeiträgen ersetzt weder Rechtsgrundlage noch Berechtigung.

Begründung

Die rechtliche Bewertung hängt von Zweck, Daten, Rolle und Wirkung des konkreten Einsatzes ab und kann nicht aus der lokalen Betriebsform allein abgeleitet werden.

Umsetzung im Geltungsbereich

Die zuständigen Funktionen prüfen den Anwendungsfall beziehungsweise das Nutzungsprofil im bestehenden Verfahren. Eine erneute vollständige Prüfung jeder gleichartigen Anfrage ist nicht erforderlich. Änderungen von Zweck, Datenarten, Empfängerkreis oder Dienst werden bewertet. Bei personenbezogenen Daten werden Zulässigkeit, Transparenz, Minimierung, Betroffenenrechte und gegebenenfalls Folgenabschätzung berücksichtigt. Die freiwillige Entscheidung nach KI-RAG-004 berechtigt nicht zur Offenlegung fremder Personal-, Kunden- oder Unternehmensdaten.

⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8, 10 und 12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7, S. 26–28 und S. 33–35, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschatz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 24–25 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Govern-, Map-, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

Prüfziel

Feststellen, ob jeder freigegebene Anwendungsfall eine aktuelle, nachvollziehbare und von zuständigen Rollen bestätigte Prüfung besitzt.

Erwartete Nachweise

Rechts- und Datenschutzmatrix; Verzeichnis von Verarbeitungstätigkeiten; Datenschutz-Folgenabschätzung oder dokumentierte Nicht-Erforderlichkeit; Beteiligungs- und Freigabenachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Planung; Freigabe; Änderung; Rechtsstelle; Datenschutzbeauftragte; Personalvertretung; Fachverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.5, CON.2; ISO: ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2

Quellen

[Q-EU-001] Art. 2–4, 26–27; [Q-BFDI-001] Kap. 1–7; [Q-DSK-001] Auswahl bis Beendigung⁸

KI-REC-002 – Schutzbedarf und Geheimschutzfreigabe

Normative Anforderung

Eingaben, Ausgaben, Modelle, Wissensbestände und abgeleitete Daten MÜSSEN nach dem allgemeinen IT-Sicherheitskonzept klassifiziert und in einer für ihren Schutzbedarf zulässigen Umgebung verarbeitet werden. Besondere gesetzliche oder unternehmensinterne Freigaben MÜSSEN vor der jeweiligen Verarbeitung wirksam vorliegen.

Begründung

Aus Quelldaten abgeleitete Darstellungen können schutzbedürftige Inhalte bewahren oder eine Rekonstruktion ermöglichen. Ein allgemeiner KI-Zugang darf keine Geheimschutzentscheidung treffen.

Umsetzung im Geltungsbereich

Vorhandene Klassifikations- und Bereichsfreigaben werden genutzt. Jede Verarbeitung muss vom freigegebenen Zweck, Datenumfang und Empfängerkreis abgedeckt sein; sie benötigt deshalb nicht automatisch eine neue Einzelgenehmigung. Eine KI-Funktion oder Nutzerzustimmung kann bestehende Schutz- und Geheimschutzgrenzen nicht aufheben.

Prüfziel

Prüfen, ob alle Datenformen erfasst sind und besonders geschützte Inhalte ohne dokumentierte Freigabe zuverlässig blockiert werden.

⁸ Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 2–4, 26–27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 1–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, Stand 06.05.2024, Auswahl bis Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026.

Erwartete Nachweise

Schutzbedarfsfeststellung; Datenfluss- und Klassifikationsmatrix; Freigaben; technische Richtlinien; negative Verarbeitungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Planung; Nutzung; Änderung; Informationssicherheitsbeauftragte; Geheimschutzbeauftragte; Datenschutzbeauftragte; Datenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.10, ORP.4; ISO: ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13

Quellen

[Q-BMI-001] S. 25–27; [Q-SUEG-001] § 4; [Q-VSA-001] Einstufungs- und Handhabungsregeln; [Q-DSK-003] Kap. 2–5⁹

9.4 Lokale Systemarchitektur und Vertrauensgrenzen

KI-ARC-001 – Explizite Zonen und einziger kontrollierter KI-Zugang

Normative Anforderung

KI-Dienste MÜSSEN mit dokumentierten Systemgrenzen und kontrollierten Zugangswegen in das Unternehmensnetz eingebunden sein. Identitäts-, Berechtigungs- und Werkzeugregeln DÜRFEN nicht über direkte Modell-, Verwaltungs- oder Diagnoseschnittstellen umgangen werden.

Begründung

Direkte Rohschnittstellen umgehen zentrale Identitäts-, Richtlinien-, Protokollierungs- und Begrenzungsentscheidungen.

Umsetzung im Geltungsbereich

Zentrale KI-Dienste erhalten einen kontrollierten Zugang und angemessen getrennte Server- und Verwaltungsbereiche. Eine verwaltete lokale Ausführung auf Endgeräten ist mit gleichwertiger Durchsetzung zulässig. Netzsegmentierung, Transportverschlüsselung und Fernzugriff folgen dem IT-Sicherheitskonzept; erlaubte Zugänge und Vertrauensübergänge werden inventarisiert und risikobasiert geprüft. KI-Ressourcen werden gemäß KI-THR-002 von der übrigen Betriebsfähigkeit entkoppelt.

⁹ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–27, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023, Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026.

Prüfziel

Inventarisierte Nutzungs- und Verwaltungszugänge mit berechtigten und unberechtigten Identitäten prüfen. Repräsentative direkte Schnittstellenzugriffe dürfen die vorgesehenen Regeln nicht umgehen.

Erwartete Nachweise

Aktuelles Zonen- und Datenflussmodell; Firewall- und Proxyregeln; Portinventar; positive und negative Netztests; Konfigurationsauszüge.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Architektur; Einführung; Betrieb; Netzverantwortliche; Systemverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, NET.3.2; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Quellen

[Q-BSI-001] S. 11–12; [Q-BMVG-001] S. 23–26; [Q-ENISA-001] Multilayer framework¹⁰

KI-ARC-002 – Unternehmensintegration und freigegebene Datenflüsse

Normative Anforderung

Lokale Inferenz MUSS im Standardmodell bevorzugt und externe Inferenz standardmäßig deaktiviert sein. Bestehende freigegebene Unternehmensdienste einschließlich Identitätsdiensten, Datenablagen und Entwicklungsdiensten DÜRFEN gemäß IT-Sicherheitskonzept integriert werden. Externe KI-Verarbeitung benötigt zusätzlich die ausdrückliche Freigabe nach KI-EXT-001.

Begründung

Unkontrollierter ausgehender Netzwerkverkehr ermöglicht Datenabfluss, Telemetrie, Lieferkettengriffe und unbeabsichtigte Ausweichverbindungen zu Cloud-Diensten außerhalb der festgelegten Systemgrenze.

Umsetzung im Geltungsbereich

Datenflüsse, Ziele und Schutzbedingungen werden anhand der bestehenden Netz- und Internetregeln festgelegt. Die Freigabe eines Internetzugangs oder eines cloudgestützten Identitätsdienstes ist keine Freigabe externer KI. Lokale Inferenz verwendet lokale Modellberechnung; angebundene Unternehmensdienste werden mit ihren tatsächlichen Verarbeitungsorten dokumentiert. Nicht freigegebene Ziele und automatische Umgehungswege bleiben gesperrt.

¹⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 23–26, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, Stand 2023, veröffentlicht am 15.11.2023, Multilayer framework, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

Prüfziel

Zulässige Unternehmensdienste und lokale Modellberechnung positiv prüfen; nicht freigegebene externe KI-Ziele und Ausweichwege müssen abgewiesen werden.

Erwartete Nachweise

System- und Datenflussübersicht; Verweise auf Netz- und Internetfreigaben; Liste freigegebener KI-Ziele; positive und negative Verbindungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Architektur; Betrieb; Änderung; Netzverantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschatz: NET.1.1.1, OPS.1.1.10; ISO: ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20

Quellen

[Q-BSI-001] S. 9–12; [Q-BMI-001] S. 25–28; [Q-NCSC-001] Secure deployment und operation¹¹

9.5 Container-, Inferenz- und API-Sicherheit

KI-CON-001 – Standardmäßig verweigerte Containerkommunikation

Normative Anforderung

Bei Containerbetrieb MÜSSEN zulässige Kommunikationsbeziehungen und Vertrauensgrenzen durchgesetzt werden. Ein internes Container- oder Pod-Netz DARF nicht als alleiniger Zugriffsschutz gelten.

Begründung

Kompromittierte Dateiauswerter, Benutzungsoberflächen oder Agentendienste könnten sonst unerlaubt Inferenzdienste, Datenbanken, Verwaltungs- oder Nachweisschnittstellen erreichen.

Umsetzung im Geltungsbereich

Die vorhandenen Plattform- und Netzregeln des IT-Sicherheitskonzepts werden auf Inferenz, Datenaufbereitung und Verwaltung angewendet. Nicht benötigte Verbindungen bleiben gesperrt; genehmigte Unternehmensdienste bleiben erreichbar. Diagnoseschnittstellen und privilegierte Netze erhalten gesonderte Zugriffsregeln.

¹¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–28, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026.

Prüfziel

Durch Soll-Ist-Abgleich und negative Verbindungstests nachweisen, dass ausschließlich modellierte Dienstbeziehungen möglich sind.

Erwartete Nachweise

Kommunikationsmatrix; Netzwerkrichtlinien beziehungsweise gleichwertige Regeln; Firewallregeln des Serverbetriebssystems; automatisierte Netztests; Abweichungsliste.

Steuermerkmal	Ausprägung
Anwendbarkeit	Containerbetrieb
Lebenszyklus und Rollen	Architektur; Einführung; Betrieb; Plattformverantwortliche; Netzverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.3.4, SYS.1.6; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Quellen

[Q-K8S-001] NetworkPolicySpec, ingress und egress; [Q-PODMAN-001] Network management; [Q-BSI-001] S. 11–12¹²

KI-CON-002 – Minimale Containerprivilegien und unveränderbare Laufzeit

Normative Anforderung

Bei Containerbetrieb MÜSSEN Laufzeit, Dienstkonten, Dateisysteme und Schnittstellen nach dem Plattform-Sicherheitskonzept mit den erforderlichen Minimalrechten betrieben werden. Privilegierte Funktionen benötigen eine begründete Freigabe.

Begründung

Dateiauswerter und KI-nahe Dienste verarbeiten potenziell schädliche Inhalte. Übermäßige Rechte erhöhen die Auswirkung einer Kompromittierung auf Serverbetriebssystem, Modelle und Daten.

Umsetzung im Geltungsbereich

Vorhandene Härtings-, Patch- und Schwachstellenprozesse gelten auch für KI-Container. Nicht privilegierter Betrieb, begrenzte Mounts, Ressourcen und Laufzeitrechte werden nach unterstützten Plattformfunktionen umgesetzt; erforderliche Ausnahmen erhalten gleichwertige Schutzmaßnahmen und eine Risikobehandlung. Container sind keine Voraussetzung für eine zulässige KI-Nutzung auf verwalteten Endgeräten.

Prüfziel

Prüfen, ob kein produktiver KI-Dienst unbegründete Rechte auf das Serverbetriebssystem, Geräte, den Betriebssystemkern oder Dateisysteme besitzt.

¹² The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1, Online-Dokumentation, Abrufstand 02.09.2026, NetworkPolicySpec, ingress und egress, <https://kubernetes.io/docs/reference/kubernetes-api/networking/network-policy-v1/>, abgerufen am 02.09.2026. | Podman Project: podman-network, Online-Dokumentation, Abrufstand 02.09.2026, Network management, <https://docs.podman.io/en/latest/markdown/podman-network.1.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

Erwartete Nachweise

Freigegebener Laufzeitausgangsstand; Bereitstellungsmanifeste; effektive Laufzeitkonfiguration; Abweichungsgenehmigungen; Abweichungsberichte.

Steuermerkmal	Ausprägung
Anwendbarkeit	Containerbetrieb
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Plattformverantwortliche; Systemverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: SYS.1.6, OPS.1.1.2; ISO: ISO/IEC 27002:2022 8.9, ISO/IEC 27002:2022 8.27

Quellen

[Q-DOCKER-001] Rootless mode; [Q-NCSC-001] Secure deployment und operation; [Q-ENISA-001] Infrastruktur- und Komponentenebene¹³

KI-API-001 – Unternehmensanmeldung und kontrollierter KI-Zugang

Normative Anforderung

Der KI-Zugang MUSS die nutzende Identität und deren Berechtigungen verlässlich prüfen und durchsetzen. Eine bestehende Unternehmensanmeldung DARF ohne zusätzliche KI-Anmeldung genutzt werden, wenn der Identitätskontext vertrauenswürdig übernommen wird. Netzwerkzugehörigkeit allein genügt nicht.

Begründung

Einige lokale Inferenzschnittstellen besitzen keine eigene Authentisierung oder schützen mit einem API-Schlüssel nicht sämtliche sensiblen Endpunkte.

Umsetzung im Geltungsbereich

Vorhandene Identitätsdienste und Single Sign-on werden nach dem IT-Sicherheitskonzept eingebunden, einschließlich freigegebener cloudgestützter Dienste. Die Anwendung prüft den übergebenen Kontext, Rollen und Gültigkeit. Gemeinsame API-Schlüssel dürfen als geschützte Dienstzugänge dienen, wenn einzelne Nutzer weiterhin zugeordnet und individuell gesperrt werden können. Direkte Endpunkte dürfen diese Prüfung nicht umgehen; MFA und Sitzungsregeln folgen dem Unternehmensstandard.

Prüfziel

Gültige Anmeldung und Rollenübernahme sowie abgelaufene, manipulierte und widerrufenen Kontexte prüfen. Ein nicht angemeldeter Netzteilnehmer darf keinen Nutzerzugriff erhalten.

¹³ Docker, Inc.: Rootless mode, Online-Dokumentation, Abrufstand 02.09.2026, Rootless mode, <https://docs.docker.com/engine/security/rootless/>, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure deployment and operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, Stand 2023, veröffentlicht am 15.11.2023, Infrastruktur- und Komponentenebene, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

Erwartete Nachweise

Identitäts- und Rollenbindung; Konfiguration des KI-Zugangs; Nachweis individueller Zurechnung und Sperrbarkeit; positive und negative Anmeldungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Einführung; Betrieb; Identitätsverantwortliche; Verantwortliche für den KI-Zugang; Plattformverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: ORP.4, APP.6, CON.1; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5

Quellen

[Q-OLLAMA-001] Local access; [Q-VLLM-001] Security und API server; [Q-OPENWEBUI-002] Authentication und API endpoints; [Q-BSI-001] S. 12¹⁴

KI-API-002 – Serverseitige Modell-, Kontext-, Anfrage- und Werkzeuggrenzen

Normative Anforderung

Freigegebene Modelle, Datenkontexte, Werkzeuge und Nutzungsgrenzen MÜSSEN unabhängig vom Sprachmodell durchgesetzt werden. Anfragen außerhalb des zugelassenen Funktions- und Berechtigungsumfangs MÜSSEN abgewiesen werden.

Begründung

Manipulierte oder fehlerhaft konfigurierte Clients können sonst nicht freigegebene Modelle, übermäßige Ressourcen oder privilegierte Funktionen anfordern.

Umsetzung im Geltungsbereich

Vorhandene Rollen werden mit geeigneten Modell-, Kontext-, Raten- und Werkzeugprofilen verbunden. Übliche sichere Parameter können freigegebene Vorgaben verwenden; Erweiterungen sicherheitsrelevanter Fähigkeiten benötigen eine Prüfung. Vertreter der erlaubten und verbotenen Anfrageklassen werden getestet; nicht abgedeckte Kombinationen werden im Bedrohungsmodell berücksichtigt.

Prüfziel

Repräsentative erlaubte und unerlaubte Anfragen über alternative Clients, manipulierte Parameter und direkte Endpunkte prüfen; die getesteten Umgehungen müssen verhindert und angemessen protokolliert werden.

¹⁴ Ollama: Authentication, Online-Dokumentation, Abrufstand 02.09.2026, Local access, <https://docs.ollama.com/api/authentication>, abgerufen am 02.09.2026. | vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026. | Open WebUI: API Endpoints, Online-Dokumentation, Abrufstand 02.09.2026, Authentication und API endpoints, <https://docs.openwebui.com/reference/api-endpoints/>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

Erwartete Nachweise

Richtlinien des KI-Zugangs; Modellfreigabeliste; Grenzwertkatalog; negative Umgehungstests; Nachweise zur Anfragebegrenzung und Alarmierung.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Verantwortliche für den KI-Zugang; KI-Verantwortliche; Fachverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: APP.6, DER.1; ISO: ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

Quellen

[Q-BSI-001] S. 11–16; [Q-VLLM-001] Security und API server; [Q-OWASP-001] übermäßige Handlungsfreiheit und Ressourcenverbrauch¹⁵

9.6 Modellbeschaffung, Herkunftsnachweis, Integrität und Austausch

KI-MOD-001 – Kontrollierter Modellimport und Herkunftsnachweis

Normative Anforderung

Lokal bereitgestellte Modelle und zugehörige Artefakte MÜSSEN vor Nutzung auf nachvollziehbare Herkunft, Integrität, zulässige Nutzung und bekannte Risiken geprüft werden. Die vorhandenen Beschaffungs-, Software- und Freigabeprozesse MÜSSEN hierfür genutzt werden.

Begründung

Modelle sind ausführbare beziehungsweise interpretierte Lieferkettenartefakte. Manipulierte Gewichte oder Formate können Fehlverhalten, Schadcode oder Datenabfluss ermöglichen.

Umsetzung im Geltungsbereich

Offizielle beziehungsweise freigegebene Quellen, Version und Prüfsumme werden erfasst; verfügbare Signaturen werden geprüft. Fehlende Herstellersignaturen werden nicht fingiert, sondern durch dokumentierte Herkunfts- und Integritätsprüfung behandelt. Modellcode und Pakete durchlaufen die bestehenden Prüfwege. Vier-Augen-Prüfung und separate Testumgebung richten sich nach Unternehmensvorgaben und Änderungsrisiko. Prüfsummen belegen Integrität, nicht Schadlosigkeit.

Prüfziel

Herkunft und Integrität eines freigegebenen Artefakts nachweisen; manipulierte oder nicht freigegebene Varianten müssen vor produktiver Nutzung erkannt beziehungsweise abgewiesen werden.

¹⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, übermäßige Handlungsfreiheit und Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

Erwartete Nachweise

Herkunfts- und Versionsnachweis; Prüfsummen; verfügbare Signaturprüfungen; Lizenz- und Softwarefreigabe; Import- und Manipulationstest.

Steuermerkmal	Ausprägung
Anwendbarkeit	Lokale Artefakte
Lebenszyklus und Rollen	Beschaffung; Import; Freigabe; Modellverantwortliche; Informationssicherheitsbeauftragte; Beschaffung
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.10, OPS.1.1.6; ISO: ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19

Quellen

[Q-BSI-001] S. 9–10; [Q-NCSC-001] Secure development und deployment; [Q-OWASP-001] Lieferkettenrisiken¹⁶

KI-MOD-002 – Versionierte Modellfreigabe und Rückkehr zur Vorversion

Normative Anforderung

Verwendete Modell- und Laufzeitstände MÜSSEN soweit technisch verfügbar eindeutig dokumentiert und ihrem Freigabestand zugeordnet sein. Wesentliche Änderungen MÜSSEN nach KI-VAL-002 bewertet werden; unsichere Stände MÜSSEN abschaltbar sein.

Begründung

Gleich benannte Modelle oder geänderte Laufzeiten können abweichendes Verhalten zeigen. Die Trennung des Fachwissens über RAG ermöglicht kontrollierten Austausch.

Umsetzung im Geltungsbereich

Bei lokalen Modellen werden Artefaktversionen und Prüfsummen genutzt, bei externen Diensten verfügbare Anbieter- und Versionskennungen. Nicht fixierbare Anbieteränderungen werden als Einschränkung dokumentiert und durch Änderungsbeobachtung sowie geeignete Wiederholungsprüfungen behandelt. Ein vorheriger zulässiger Stand oder ein bereits freigegebenes Modell kann optional genutzt werden. Wiederherstellung darf widerrufene Rechte und gelöschte Inhalte nicht reaktivieren.

Prüfziel

Laufenden Modellstand dem dokumentierten Freigabestand zuordnen; Abschaltung und den vorgesehenen Reparatur- beziehungsweise Rückkehrweg einschließlich aktueller Rechte prüfen.

¹⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–10, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure development und deployment, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Lieferkettenrisiken, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

Erwartete Nachweise

Freigabemanifest; Modell- und Laufzeitprüfsummen; Bewertungsbericht; Änderungsfreigabe; dokumentierter Rückkehrtest; RAG-Kompatibilitätsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Freigabe; Änderung; Betrieb; Modellverantwortliche; Testverantwortliche; Änderungsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.3, OPS.1.1.6; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 9–12; [Q-BMVG-001] S. 25–32; [Q-ISO-5338] öffentliche Metadaten zum KI-Systemlebenszyklus¹⁷

9.7 Ausdrückliches Trainings- und Feinabstimmungsverbot

KI-TRN-001 – Keine Änderung von Modellgewichten

Normative Anforderung

Training, Fine-Tuning, LoRA, PEFT, RLHF, selbsttätiges Lernen und produktive Änderungen der Modellgewichte MÜSSEN ausgeschlossen bleiben. Die geregelte Ergänzung eines extern zum Modell geführten Wissensbestands nach KI-RAG-004 DARF nicht als Modelltraining behandelt werden.

Begründung

Training eröffnet eigenständige Risiken für Datenrecht, Datenqualität, Modellintegrität, Reproduzierbarkeit und Freigabe. Basismodelle bleiben austauschbar; Fachwissen verbleibt außerhalb der Gewichte.

Umsetzung im Geltungsbereich

Trainingsaufträge, lernende Rückkopplungen und Schreibzugriffe auf produktive Modellgewichte werden organisatorisch und technisch unterbunden. Bibliotheken mit zusätzlichen Trainingsfähigkeiten dürfen für die Inferenz vorhanden sein, wenn diese Fähigkeiten nicht zugänglich oder ausführbar sind. RAG-Indexierung, Suchvektoren, Systemanweisungen und Gesprächskontext ändern die Modellgewichte nicht; für deren Daten gelten die jeweiligen Schutzregeln.

¹⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 25–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, öffentliche Metadaten zum KI-Systemlebenszyklus, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

Prüfziel

Mit repräsentativen Negativtests und Rechteprüfung belegen, dass Trainingsjobs und Änderungen produktiver Modellgewichte nicht ausgeführt werden können; reine RAG-Indexierung bleibt im genehmigten Umfang möglich.

Erwartete Nachweise

Software- und Jobinventar; schreibgeschützte Modellablage; Dateintegritätsmessung; Datenflussprüfung; negative Trainingstests; Freigaberegeln.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; KI-Verantwortliche; Plattformverantwortliche; Datenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: APP.6, OPS.1.1.3; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning; [Q-BMVG-001] S. 25–32 zum kontrollierten Lebenszyklus; [Q-ISO-5338] öffentliche Lebenszyklusmetadaten¹⁸

9.8 Sicherheit der lokalen Wissensuche, Suchvektoren und Dateiübernahmen

KI-RAG-001 – Kontrollierte Aufnahme und isolierte Dokumentenaufbereitung

Normative Anforderung

Dateien und Wissensquellen MÜSSEN über kontrollierte Aufnahmewege auf zulässigen Typ, Größe, Schadsoftware und aktive Inhalte geprüft werden. Auswertung und Konvertierung MÜSSEN mit begrenzten Rechten und Ressourcen sowie ausschließlich erforderlichen, freigegebenen Verbindungen erfolgen.

Begründung

Dokumente sind nicht als Steueranweisung vertrauenswürdig. Sie können Schwachstellen der Dateiauswertung, aktive Inhalte, Ressourcenangriffe oder eingeschleuste Anweisungen enthalten.

Umsetzung im Geltungsbereich

Vorhandene Dokumenten-, Qualitäts-, Schadsoftware- und Konfigurationsprozesse werden verwendet. Ein für KI-Wissensarbeit freigegebener Bestand darf innerhalb seiner Zweck- und Berechtigungs-

¹⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 25–32 zum kontrollierten Lebenszyklus, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, öffentliche Lebenszyklusmetadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

grenzen regulär indexiert werden. Zusätzliche Einzelfreigaben allein wegen KI entfallen. Nicht vertrauenswürdig geprüfte Dateien werden isoliert aufbereitet; fehlerhafte und unzulässige Dateien werden abgewiesen. Persönliche Beiträge unterliegen zusätzlich KI-RAG-004.

Prüfziel

Mit präparierten Dateien prüfen, ob Typumgehung, aktive Inhalte, Schadsoftware, Abstürze der Dateiauswertung und Ressourcenüberschreitungen sicher behandelt werden.

Erwartete Nachweise

Richtlinie für Dateiübernahmen; Sicherheitsprofil der Dateiauswerter; Schadsoftware- und Typprüfprotokolle; Ressourcengrenzen; negative Testdateisammlungen; Quarantäne- und Löschprotokolle.

Steuermerkmal	Ausprägung
Anwendbarkeit	Dateiaufnahme
Lebenszyklus und Rollen	Aufnahme; Betrieb; RAG-Verantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, SYS.1.6; ISO: ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26

Quellen

[Q-DSK-003] Kap. 2–5; [Q-DSK-002] Kap. 2–6; [Q-OWASP-001] Prompt Injection und Ressourcenverbrauch¹⁹

KI-RAG-002 – Durchgängige Berechtigungsprüfung und Indextrennung

Normative Anforderung

Vor Aufnahme und bei jeder Abfrage MUSS die Berechtigung anhand der maßgeblichen Unternehmensquelle geprüft werden. Zugriffsentscheidungen DÜRFEN weder Systemanweisungen noch dem Sprachmodell überlassen werden. Quellen, Zusammenfassungen, Textabschnitte, Suchvektoren, Indizes, Zwischenspeicher und Antworten MÜSSEN die zulässigen Empfängerkreise wahren.

Begründung

Ein gemeinsamer Suchindex oder nur durch Anweisungen gesteuerte Filter können geschützte Textausschnitte über die inhaltliche Ähnlichkeitssuche, Zwischenspeicher oder Modellausgaben offenlegen.

Umsetzung im Geltungsbereich

Herkunft, Zweck, Schutzbedarf und Rechte werden bei der Aufbereitung übernommen. Der Suchdienst begrenzt Treffer vor ihrer Übergabe an das Modell auf die aktuelle Nutzerberechtigung. Ge-

¹⁹ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Prompt Injection und Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

mischte oder zusammengefasste Inhalte dürfen geschützte Informationen keinem größeren Empfängerkreis offenlegen; eine Modellzusammenfassung ist kein Nachweis sicherer Anonymisierung. Unklare Rechte oder Zwecke verhindern automatische Aufnahme. Änderungen und Widerrufe folgen den festgelegten Übernahmefristen des IAM-Prozesses einschließlich begrenzter Gültigkeit zwischengespeicherter Rechte und eines dringlichen Sperrwegs. Ist die Berechtigung nicht verlässlich feststellbar, wird der Zugriff abgewiesen.

Prüfziel

Mit verschiedenen berechtigten Identitäten Aufnahme, Abfrage, direkte Objektzugriffe, Zusammenfassungen und Zwischenspeicher testen. Personal- oder Kundendaten einer Leitungsperson dürfen nach Verarbeitung nicht für unberechtigte Beschäftigte auffindbar werden. Widerrufe innerhalb der festgelegten Frist nachweisen.

Erwartete Nachweise

Zugriffsregeln und Zuordnung der Identitäten; Indexschema; Filterkonfiguration; nachgewiesene Übernahmezeit von Berechtigungswiderrufen; positive und negative Berechtigungstests; Tests der Zwischenspeicher.

Steuermerkmal	Ausprägung
Anwendbarkeit	Wissenssuche
Lebenszyklus und Rollen	Aufnahme; Abfrage; Änderung; Datenverantwortliche; RAG-Verantwortliche; Identitätsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3

Quellen

[Q-DSK-003] Kap. 2–5; [Q-BSI-001] S. 11–12; [Q-BFDI-001] Kap. 3–7²⁰

KI-RAG-003 – Schutz, Herkunft, Aufbewahrung und Löschung abgeleiteter Daten

Normative Anforderung

Suchvektoren, Textabschnitte, Indizes und Zwischenspeicher MÜSSEN mindestens wie ihre Quellen geschützt werden. Herkunft und Fundstellen MÜSSEN nachvollziehbar bleiben. Aufbewahrung, Berichtigung und Löschung MÜSSEN nach dem IT-Sicherheits- und Datenschutzkonzept auch Ableitungen und Sicherungsketten erfassen. Unzulässiger Zugriff MUSS unabhängig von der physischen Löschfrist unterbunden werden.

²⁰ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 3–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

Begründung

Abgeleitete Daten können Inhalte, Personenbezug und Schutzbedarf der Quelle bewahren. Unvollständige Löschung oder ein fehlender Herkunftsnachweis verhindert Betroffenenrechte und fachliche Prüfung.

Umsetzung im Geltungsbereich

Stabile Kennungen verbinden Quelle, Version, Rechte, Zweck und Aufbewahrung. Die Beendigung freiwilliger Wissensbeiträge stoppt neue Beiträge, entfernt bestehende aber nicht automatisch; deren weitere Nutzung richtet sich nach den zuvor erläuterten geltenden Regeln. Entfällt die Zulässigkeit oder Berechtigung, wird die weitere Nutzung unabhängig davon gesperrt. Löschaufträge entfernen Onlinekopien und Ableitungen innerhalb festgelegter Fristen; Sicherungen laufen geregelt aus. Aufbewahrungspflichten erlauben keinen regulären Suchzugriff. Bei Wiederherstellung werden aktuelle Sperr- und Löschstände erneut angewendet.

Prüfziel

Für eine Testquelle Herkunft bis zur Ausgabe, wirksame Zugriffssperre, fristgerechte Löschung der Ableitungen und Behandlung von Sicherungen nachweisen. Ein Beitragsstopp allein darf keinen unangeforderten Verlust zulässig gespeicherter Beiträge auslösen.

Erwartete Nachweise

Datenkatalog; Herkunftsmetadaten; Quellennachweise in Ausgaben; Aufbewahrungsplan; Löschprotokoll; Nachtest von Suche und Zwischenspeichern; Sicherungskonzept.

Steuermerkmal	Ausprägung
Anwendbarkeit	Abgeleitete Daten
Lebenszyklus und Rollen	Aufnahme; Nutzung; Löschung; Datenverantwortliche; RAG-Verantwortliche; Backup-Verantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, CON.3; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024

Quellen

[Q-DSK-003] Kap. 2–5; [Q-DSK-002] Kap. 2–6; [Q-BFDI-001] Kap. 4–7²¹

²¹ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 4–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-RAG-004 – Persönliche Speicherung und freiwillige Wissensbeiträge

Normative Anforderung

Persönliche Dateien, Ergebnisse und Verläufe DÜRFEN auf verwalteten Endgeräten und im persönlichen Arbeitsbereich nach den normalen Unternehmensregeln gespeichert werden, ohne zusätzliche KI-Einzelfreigabe. Die Übernahme persönlicher Agentenarbeit in Unternehmenswissen MUSS standardmäßig deaktiviert sein. Bei der ersten Nutzung und zu Beginn jedes Agentenprojekts MUSS eine freiwillige, informierte Entscheidung über diese optionale Übernahme eingeholt werden. Ohne ausdrückliche Zustimmung erfolgt keine Übernahme; normale KI-Nutzung bleibt möglich.

Begründung

Beiläufige Dateiübernahmen können unbemerkt zu dauerhaften Wissens- oder Protokollbeständen werden und Zweckbindung, Löschung sowie Zugriffsschutz unterlaufen.

Umsetzung im Geltungsbereich

Die erstmalige Einrichtung und das erste Projekt können gemeinsam abgefragt werden. Vor einer Zustimmung werden Inhalt, Zweck, Zielbestand, Empfängerkreis und der Umgang mit bestehenden Beiträgen nach einem Stopp erläutert. Aktiver Zustand und Umfang bleiben jederzeit erkennbar; neue Beiträge sind jederzeit stoppbar. Gewöhnliche Chatbot-Dialoge fließen nicht automatisch in Unternehmenswissen ein, auch wenn sie vorhandenes Wissen abrufen. Ein Projektwechsel erfordert eine neue Entscheidung. Zustimmung erweitert keine Quellrechte und ersetzt keine rechtliche Zulässigkeit. Bestehende Bereichsfreigaben erlauben keine stillschweigende Übernahme persönlicher Interaktionen. Fehlen Zustimmungserfassung, sichtbarer Status oder sichere Rechteübernahme, bleibt nur diese optionale Funktion aus. Bei externer KI gelten zusätzlich die freigegebenen Bedingungen zur Anbieterverarbeitung; Produktnamen bestimmen nicht den Funktionsumfang.

Prüfziel

Ersteinrichtung, Projektwechsel, Ablehnung, Zustimmung, sichtbaren Zustand und Beitragsstopp prüfen. Persönliche Speicherung muss bei Ablehnung weiter funktionieren; Chatfragen und Dateien dürfen nicht unbemerkt im Unternehmensindex erscheinen. Mit geschützten Testdaten unzulässige Empfänger ausschließen.

Erwartete Nachweise

Beschreibung der Speicher- und Beitragsfunktion; Entscheidung je Agentenprojekt; Anzeige von Zustand, Umfang und Ziel; Rechte- und Übernahmetests; geltende Aufbewahrungs- und Nutzungsregeln.

Steuermerkmal	Ausprägung
Anwendbarkeit	Persönliche Daten
Lebenszyklus und Rollen	Nutzung; Löschung; Nutzende; RAG-Verantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, APP.6; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12

Quellen

[Q-DSK-003] Kap. 2–5; [Q-BMI-001] S. 25–29²²

9.9 Identitäten, Rollen, technische Konten und Geheimnisse

KI-IAM-001 – Minimalrechte und Umgang mit Zugangsdaten und Geheimnissen für KI-Dienste

Normative Anforderung

Nutzer-, Dienst- und Administrationsidentitäten MÜSSEN zweckgebunden, minimal berechtigt und verantwortlich zugeordnet sein. Nutzerzugriffe MÜSSEN individuell widerrufbar bleiben. Geheimnisse DÜRFEN nicht in Eingaben, normalen Projektdateien, Abbildern, Modellen, Verläufen oder Protokollen offengelegt werden.

Begründung

Agentische Werkzeuge und KI-Dienste verbinden Dateisysteme, APIs und Entwicklungswerkzeuge; ein gemeinsames Konto vergrößert Wirkung und erschwert Zurechnung.

Umsetzung im Geltungsbereich

Der bestehende Identitäts-, Berechtigungs- und Geheimnisprozess gilt für KI-Dienste. Unternehmensanmeldung und MFA werden nach KI-API-001 wiederverwendet. Gemeinsame Dienstschlüssel bleiben geschützt; die Nutzerzuordnung bleibt unabhängig davon erhalten. Widerrufsfristen, Sitzungs- und Gültigkeit zwischengespeicherter Rechte sowie dringliche Sperren werden im IAM-Prozess festgelegt und geprüft. Geheimnisse werden nur über die vorgesehene Geheimnisverwaltung bereitgestellt; Protokolle vermeiden sensible Werte.

Prüfziel

Prüfen, ob effektive Rechte dem genehmigten Zweck entsprechen, Widerruf wirksam ist und Geheimnisse weder in typischen Eingabe- noch Ausgabepfaden erscheinen.

Erwartete Nachweise

Rollen- und Kontenregister; erneute Berechtigungsprüfung; Konfiguration der Geheimnisablage; Widerrufstest; Suchlauf in Codeablagen und Protokollen; Administrationsnachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Identitätsverantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, CON.7; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2

²² Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

Quellen

[Q-BSI-001] S. 8–13; [Q-BMI-001] S. 25–29; [Q-DSK-002] Kap. 2–6²³

9.10 Chat-Oberflächen und agentische Clientanwendungen

KI-AGT-001 – Genehmigte Arbeitsbereiche und wirksame Zugriffsgrenzen

Normative Anforderung

Agentische Clients MÜSSEN im genehmigten Aufgaben-, Daten- und Berechtigungsumfang arbeiten. Erforderliche Projektdateien, freigegebene Wissensquellen und Unternehmensdienste DÜRFEN innerhalb dieses Umfangs genutzt werden. Pauschale Administratorrechte allein wegen KI-Nutzung DÜRFEN nicht erteilt werden.

Begründung

Agentische Anwendungen können Modellentscheidungen in reale Datei- und Quellcodeänderungen übersetzen. Breite Rechte verwandeln Fehlanweisungen oder eingeschleuste Anweisungen in unmittelbare Schäden.

Umsetzung im Geltungsbereich

Arbeitsprofile verbinden gewöhnliche Nutzerrechte mit zugelassenen Projekten, Quellen, Werkzeugen und Verbindungen. Betriebssystem-, Anwendungs- oder vergleichbare Kontrollen begrenzen die Wirkung unabhängig vom Modell. Routinearbeit einschließlich Codebearbeitung, Analyse, Tests und Dateiablage benötigt keine zusätzliche Einzelbestätigung. Für Änderungen und Löschungen gelten die Wiederherstellungs- und Bestätigungsgrenzen aus KI-TOL-001.

Prüfziel

Erlaubte Projektarbeit positiv und Zugriffe außerhalb des genehmigten Umfangs negativ prüfen. Wiederherstellung repräsentativer Änderungen durch einen normalen Nutzer nachvollziehen.

Erwartete Nachweise

Clientrichtlinie; wirksame Dateirechte; Profil der abgeschotteten Ausführungsumgebung; Rollenfreigabe; negative Pfad- und Privilegentests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Agenten
Lebenszyklus und Rollen	Einführung; Nutzung; Clientverantwortliche; Fachverantwortliche; Nutzende

²³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

Steuermerkmal	Ausprägung
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18

Quellen

[Q-BSI-001] S. 12–16; [Q-CLINE-001] Provider- und Endpunktconfiguration; [Q-OPENCODE-001] lokale Modelle und Provider²⁴

KI-AGT-002 – Freigegebene KI-Ziele für agentische Anwendungen

Normative Anforderung

Agentische Clients MÜSSEN ausschließlich für den Zweck und die Daten freigegebene KI-Umgebungen verwenden. Automatische Wechsel DÜRFEN nur innerhalb eines bereits freigegebenen Ausweichprofils erfolgen.

Begründung

Kompatible Endpunktconfigurationen erleichtern den unbeabsichtigten Wechsel zu externen Diensten und umgehen zentrale Modellfreigaben.

Umsetzung im Geltungsbereich

Lokale Modelle werden bevorzugt; zusätzliche lokale oder ausdrücklich freigegebene externe Modelle können konfiguriert werden. Unternehmensanmeldung und freigegebene Entwicklungsdienste bleiben nutzbar. Anbietererkennung, Erweiterungen oder Fehlerbehandlung dürfen kein neues KI-Ziel aktivieren. Telemetrie und Internetverbindungen folgen dem IT-Sicherheitskonzept und den jeweiligen Datenfreigaben; KI-EXT-001 und KI-EXT-002 gelten zusätzlich.

Prüfziel

Manipulierte Clientkonfigurationen und alternative Anbieter müssen blockiert oder erkannt werden; der wirksame Endpunkt ist serverseitig und im Netzprotokoll nachweisbar.

Erwartete Nachweise

Freigegebener Clientausgangsstand; Anbieterfreigabeliste; Konfigurationsschutz; Protokolle zu ausgehendem Netzwerkverkehr und DNS; negative Anbieter- und Ausweichverbindungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Agenten
Lebenszyklus und Rollen	Einführung; Betrieb; Clientverantwortliche; Netzverantwortliche; KI-Verantwortliche

²⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, Provider- und Endpunktconfiguration, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, lokale Modelle und Provider, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026.

Steuermerkmal	Ausprägung
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, NET.1.1; ISO: ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20

Quellen

[Q-OPENWEBUI-001] OpenAI-kompatible Anbindung; [Q-CLINE-001] OpenAI-Compatible Providers; [Q-OPENCODE-001] Local models; [Q-LLAMACPP-001] llama-server-Verweise²⁵

9.11 Eingeschleuste Anweisungen, Datenabfluss und unsichere Modellausgaben

KI-PMT-001 – Nicht vertrauenswürdige Inhalte und eingeschleuste Anweisungen

Normative Anforderung

Eingaben, Dokumente, Webseiten, Quellcode und Werkzeugausgaben MÜSSEN als potenziell manipulierte Inhalte behandelt werden. Darin enthaltene Anweisungen DÜRFEN den erteilten Auftrag, die Werkzeugrichtlinie oder Berechtigungsgrenzen nicht erweitern.

Begründung

Sprachmodelle unterscheiden Anweisungen und Daten nicht zuverlässig. Indirekt eingeschleuste Anweisungen können über vertrauenswürdige erscheinende Quellen Aktionen oder Datenabfluss anstoßen.

Umsetzung im Geltungsbereich

Daten und steuernde Vorgaben werden getrennt verarbeitet. Modelle dürfen aufgabenbezogene Aktionen vorschlagen; deren Zulässigkeit wird unabhängig vom Modell nach KI-TOL-001 durchgesetzt. Instruktionen in abgerufenen Daten erzeugen keine zusätzliche Genehmigung. Repräsentative Angriffe auf Quellen, Werkzeuge und Kontextübergänge werden im laufenden Prüfbestand geführt.

Prüfziel

Mit dokumentierten direkten und indirekten Angriffseingaben prüfen, dass Richtlinien, Berechtigungen, Geheimnisse und Werkzeuggrenzen nicht umgangen werden.

Erwartete Nachweise

Sammlung von Angriffsfällen; Tests mit eingeschleusten Anweisungen; Richtlinienkonfiguration; Angriffsergebnisse; Block- und Alarmprotokolle; akzeptierte Restgrenzen.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen

²⁵ Open WebUI: Starting with OpenAI-compatible providers, Online-Dokumentation, Abrufstand 02.09.2026, OpenAI-kompatible Anbindung, <https://docs.openwebui.com/getting-started/quick-start/connect-a-provider/starting-with-openai-compatible/>, abgerufen am 02.09.2026. | Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, OpenAI-Compatible Providers, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Local models, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026. | ggml-org: llama.cpp, Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee, Stand README-Stand 23.08.2026, llama-server-Verweise, <https://github.com/ggml-org/llama.cpp/tree/ccc8fd2baa64ab26c7210b02765d3604069ec7ee>, abgerufen am 02.09.2026.

Steuermerkmal	Ausprägung
Lebenszyklus und Rollen	Entwurf; Test; Nutzung; Betrieb; KI-Verantwortliche; RAG-Verantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, DER.1; ISO: ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

Quellen

[Q-BSI-001] S. 11–16; [Q-OWASP-001] Prompt Injection; [Q-NIST-002] adversariale Angriffe und Abhilfen²⁶

KI-OUT-001 – Prüfung, Kennzeichnung und menschliche Freigabe von Ausgaben

Normative Anforderung

KI-Ausgaben MÜSSEN ihrem Verwendungszweck entsprechend geprüft und sicher weiterverarbeitet werden. Die bestehenden Qualitäts-, Entwicklungs- und Freigabeverfahren MÜSSEN auch bei KI-Unterstützung gelten. Kritische Entscheidungen und nicht ausreichend beherrschbare Wirkungen benötigen die zuständige menschliche Entscheidung.

Begründung

Plausibel formulierte Fehlantworten, unsicherer Code oder eingebettete Anweisungen können automatisiert weiterverarbeitet und dadurch wirksam werden.

Umsetzung im Geltungsbereich

Routineentwürfe, Analysen, Codeänderungen und Tests nutzen die normalen Qualitätssicherungsprozesse ohne zusätzliche Freigabe allein wegen KI. Prüfumfang und erforderliche menschliche Kontrolle richten sich nach möglichem Schaden und Erkennbarkeit von Fehlern. Ungeprüfte Ausgaben werden nicht als verlässliche Tatsachen oder ausführbare Anweisungen übernommen; Werkzeugaktionen folgen KI-TOL-001.

Prüfziel

Fehlerhafte, manipulative und formal ungültige Ausgaben einspeisen und nachweisen, dass keine unkontrollierte Folgewirkung eintritt.

Erwartete Nachweise

Prüfregeln; Prüf- und Freigabeprotokolle; Kennzeichnungsvorgaben; Sammlung fehlerhafter Testausgaben; negative Weiterverarbeitungstests.

²⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Prompt Injection, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, Stand Finalfassung 2025, veröffentlicht am 24.03.2025, adversariale Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Nutzung; Freigabe; Betrieb; Nutzende; Fachverantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, OPS.1.1.6; ISO: ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023

Quellen

[Q-BMI-001] S. 29–30; [Q-BSI-001] S. 9 und S. 12–16; [Q-BMVG-001] S. 29–32²⁷

9.12 Werkzeugnutzung, Dateizugriff und Befehlsausführung

KI-TOL-001 – Getrennte Werkzeugfunktionen und Bestätigung kritischer Aktionen

Normative Anforderung

Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff MÜSSEN im genehmigten Aufgaben- und Berechtigungsumfang gesteuert werden. Routineaktionen DÜRFEN ohne Einzelgenehmigung erfolgen. Löschungen und andere destruktive Maßnahmen DÜRFEN nur dann ohne Einzelgenehmigung erfolgen, wenn der Nutzer Änderungen und maßgebliche Folgen schnell, einfach und zuverlässig rückgängig machen kann und kein erheblicher Schaden zu erwarten ist. Fehlt diese Möglichkeit, MUSS jede Löschung und destruktive Tätigkeit konkret genehmigt werden. Kritische, privilegierte oder nicht rückgängig zu machende Wirkungen benötigen ebenfalls eine konkrete Genehmigung.

Begründung

Eine pauschale Agentenfreigabe kann Modellfehler oder manipulierte Inhalte unmittelbar in irreversible Systemänderungen übersetzen.

Umsetzung im Geltungsbereich

Freigegebene Arbeitsprofile erlauben die übliche Codebearbeitung, Analyse, Tests, das Lesen und Erzeugen von Dateien sowie beherrschbare Änderungen. Versionierung, nutzbare Wiederherstellungspunkte oder gleichwertige Verfahren können Wiederherstellbarkeit sichern; ihr bloßes Vorhandensein genügt nicht. Die Methode muss die betroffenen Inhalte und Folgen tatsächlich abdecken. Auch Übertragungen in freigegebene Codeablagen können im Routineprofil erfolgen, sofern deren Wirkungen beherrschbar sind. Das Zurücksetzen einer Datei macht Offenlegung, ausgelöste Veröffentlichungen oder produktive Änderungen nicht automatisch rückgängig. Eine Genehmigung nennt betroffene Aktion, Ziel und Wirkung; sie ersetzt keine erforderliche Berechtigung. Die Durchsetzung erfolgt außerhalb des Modells.

²⁷ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 29–30, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9 und S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 29–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

Prüfziel

Routinearbeit ohne unnötige Rückfragen positiv prüfen. Löschungen mit einfacher Nutzerwiederherstellung, ohne Wiederherstellung, privilegierte Eingriffe und Übertragungen mit nicht rückgängig zu machenden Folgen unterscheiden. Nicht genehmigte kritische Wirkungen müssen blockiert werden.

Erwartete Nachweise

Arbeits- und Werkzeugprofile; nachgewiesener Wiederherstellungsweg; Protokolle repräsentativer Freigabe-, Sperr- und Wiederherstellungstests; konkrete Entscheidungen für genehmigungspflichtige Aktionen.

Steuermerkmal	Ausprägung
Anwendbarkeit	Werkzeuge
Lebenszyklus und Rollen	Entwurf; Einführung; Nutzung; Werkzeugverantwortliche; Clientverantwortliche; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18

Quellen

[Q-BSI-001] S. 12–16; [Q-OWASP-001] übermäßige Handlungsfreiheit und unsichere Ausgabe; [Q-NIST-001] Manage- und Measure-Aktionen²⁸

KI-TOL-002 – Kontrollierte Erweiterungen, MCP-Server und Werkzeugprotokollierung

Normative Anforderung

Werkzeuge, Plug-ins, MCP-Server und Erweiterungen MÜSSEN dem bestehenden Software-, Lieferketten- und Berechtigungsprozess unterliegen. Aufrufe MÜSSEN zugeordnet und mit den notwendigen Sicherheitsmetadaten nachvollzogen werden können.

Begründung

Erweiterungen bilden eine dynamische Lieferkette und können zusätzliche Rechte oder Wege für ausgehenden Netzwerkverkehr einführen. Ohne Aufrufprotokolle bleiben reale Agentenwirkungen unklar.

Umsetzung im Geltungsbereich

Freigegebene Bezugsquellen und nachvollziehbare Versionen werden verwendet. Erweiterungen erhalten nur aufgabenbezogene Rechte und freigegebene Verbindungen; wesentliche Änderungen folgen KI-VAL-002. Protokolle nennen Identität, Werkzeug, Entscheidung und Ergebnisstatus und vermeiden sensible Parameter oder Inhalte. Vorhandene Softwareinventare und Prüfprotokolle dienen als Nachweis.

²⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, übermäßige Handlungsfreiheit und unsichere Ausgabe, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Manage- und Measure-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

Prüfziel

Unfreigegebene Erweiterungen und Versionen müssen blockiert werden; für genehmigte Testaufrufe muss eine vollständige, datensparsame Nachweiskette entstehen.

Erwartete Nachweise

Vorhandenes Erweiterungsinventar; Herkunfts-, Versions- und Integritätsnachweise; Softwarefreigaben; datensparsame Werkzeugprüfprotokolle; negative Installationstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Erweiterungen
Lebenszyklus und Rollen	Beschaffung; Einführung; Nutzung; Betrieb; Werkzeugverantwortliche; Informationssicherheitsbeauftragte; Protokollierungsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: OPS.1.1.10, OPS.1.1.5; ISO: ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15

Quellen

[Q-BSI-001] S. 10–13; [Q-NCSC-001] Secure development, deployment und operation; [Q-OWASP-001] Lieferkettenrisiken²⁹

9.13 Gezielte Angriffe, Modellmissbrauch und Ressourcenerschöpfung

KI-THR-001 – KI-spezifisches Bedrohungsmodell

Normative Anforderung

Das Bedrohungsmodell MUSS KI-spezifische Missbrauchsszenarien an den inventarisierten Schnittstellen, Vertrauensgrenzen, Datenwegen und Werkzeugklassen abdecken. Sicherheitsentscheidungen MÜSSEN unabhängig vom Modell durchgesetzt und risikobasiert geprüft werden.

Begründung

Klassische Systemmodelle erfassen die nicht vollständig vorhersagbare Verarbeitung nicht vertrauenswürdiger Inhalte und die Handlungsketten agentischer Systeme nicht vollständig.

Umsetzung im Geltungsbereich

Repräsentative positive und negative Fälle erfassen insbesondere Prompt Injection, Rechteumgehung, Datenabfluss, manipulierte Artefakte, Ergebnisfehler und Ressourcenverbrauch. Abdeckung und verbleibende Unsicherheiten werden dokumentiert. Eine vollständige Vorhersage sämtlicher Modellantworten oder jeder theoretischen Kombination wird nicht vorausgesetzt. Neue relevante Wege und Erkenntnisse ergänzen den Prüfbestand.

²⁹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 10–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure development, deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Lieferkettenrisiken, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

Prüfziel

Inventar und Bedrohungsmodell auf wesentliche fehlende Übergänge prüfen; je Sicherheitsgrenze aussagekräftige erlaubte und unerlaubte Fälle ausführen und Befunde bewerten.

Erwartete Nachweise

Bedrohungsmodell mit Szenarien und Kontrollzuordnung; Schnittstelleninventar; begründete Testauswahl, Ergebnisse und bekannte Abdeckungsgrenzen.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Planung; Test; Änderung; Betrieb; Informationssicherheitsbeauftragte; KI-Verantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: DER.1, APP.6; ISO: ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023

Quellen

[Q-BSI-001] S. 12–16; [Q-BSI-2003-001] S. 5–7, S. 26–28 und S. 33–35; [Q-NIST-002] Taxonomie der Angriffe und Abhilfen; [Q-MITRE-001] Tactics and techniques; [Q-OWASP-001] LLM Top 10 2025³⁰

KI-THR-002 – Ressourcen-, Missbrauchs- und Verfügbarkeitsgrenzen

Normative Anforderung

KI-Ressourcenverbrauch MUSS durch geeignete Quoten, Zeit- und Auftragsgrenzen beherrscht werden. Überlastung oder Ausfall der KI DARF die Weiterarbeit der übrigen Unternehmensprozesse nicht verhindern. Jede Tätigkeit MUSS nach KI-GOV-002 ohne KI möglich bleiben.

Begründung

Lange Kontexte, rekursive Agentenschleifen und aufwendige Anfragen können lokale Kapazität erschöpfen und andere Dienste verdrängen.

Umsetzung im Geltungsbereich

Vorhandene Kapazitäts- und Plattformregeln werden auf Kontexte, Parallelität, Schleifen und Speicherbedarf angewendet. Verfügbare Dienstgrenzen, Warteschlangen, Abbruchmöglichkeiten und Ressourcenisolation werden passend zur Umgebung kombiniert. Langsame oder ausgefallene KI wird übergangen oder abgeschaltet. Ein Ersatzmodell, ein zweiter Server oder eine eigene KI-Wiederanlaufzeit ist keine Voraussetzung für die Weiterarbeit.

³⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7, S. 26–28 und S. 33–35, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026. | National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, Stand Finalfassung 2025, veröffentlicht am 24.03.2025, Taxonomie der Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026. | The MITRE Corporation: MITRE ATLAS, Laufend gepflegte Wissensbasis, Abrufstand 02.09.2026, Tactics and techniques, <https://atlas.mitre.org/>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, LLM Top 10 2025, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

Prüfziel

Unter repräsentativer Überlast und bei abgeschalteter KI prüfen, dass andere benötigte Anwendungen und Daten erreichbar bleiben und betroffene Tätigkeiten ohne KI fortgesetzt werden können.

Erwartete Nachweise

Ressourcen- und Kapazitätsregeln; Überlast- und Abschalttests; Nachweis unabhängiger Arbeitsabläufe; regulärer Reparaturweg.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Entwurf; Test; Betrieb; Kapazitätsverantwortliche; Plattformverantwortliche; Betriebsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: OPS.1.1.1, DER.1; ISO: ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16

Quellen

[Q-BSI-001] S. 14–16; [Q-OWASP-001] Ressourcenverbrauch; [Q-NIST-001] Measure- und Manage-Aktionen³¹

9.14 Bewertung, Freigabe, Wiederholungsprüfung und Rückkehr zur Vorversion

KI-VAL-001 – Wiederholbare Qualitäts- und Sicherheitsbewertung

Normative Anforderung

Qualitäts- und Sicherheitsprüfungen MÜSSEN mit dokumentierter Konfiguration, geeigneten Fällen und vorab bestimmten Bewertungskriterien wiederholbar sein. Stochastische Modellausgaben MÜSSEN unter Berücksichtigung ihrer Streuung bewertet werden; identischer Wortlaut ist kein allgemeines Freigabekriterium.

Begründung

Allgemeine Vergleichstests belegen weder Eignung noch Sicherheit im lokalen Anwendungsfall. Modellantworten sind variabel und benötigen wiederholbare Messungen.

Umsetzung im Geltungsbereich

Modellstand, Systemvorgaben, Datenstand und Parameter werden soweit verfügbar erfasst. Wiederholungen prüfen fachliche Eignung und Fehlerraten anhand nachvollziehbarer Schwellen. Klassische Berechtigungs- und Sperrregeln müssen zuverlässig durchgesetzt werden. Bestehende Qualitäts- und Testprozesse werden um geeignete KI-Fälle ergänzt; nicht messbare oder nicht verfügbare Herstellereigenschaften werden nicht als nachgewiesen behandelt.

³¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 14–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

Prüfziel

Konfiguration und Testauswahl nachvollziehen, repräsentative Prüfungen wiederholen und die festgelegten Kriterien einschließlich erwarteter Streuung anwenden.

Erwartete Nachweise

Versionierte Testfälle; Konfigurationen; Bewertungskriterien; wiederholte Ergebnisse mit Streuung und Befunden; Freigabeentscheidung.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Test; Freigabe; Testverantwortliche; Fachverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.6, APP.6; ISO: ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023

Quellen

[Q-BSI-001] S. 9–12; [Q-BMVG-001] S. 29–32; [Q-NIST-001] Measure-Aktionen; [Q-ISO-25059] öffentliche Metadaten zum KI-Qualitätsmodell³²

KI-VAL-002 – Änderungsabhängige Wiederholungsprüfung, Wiederfreigabe und Rückkehr zur Vorversion

Normative Anforderung

Änderungen MÜSSEN im bestehenden Änderungs- und Konfigurationsmanagement ihrem Risiko entsprechend geprüft werden. Wesentliche Änderungen an Modellen, Berechtigungen, Datenflüssen oder Sicherheitsfunktionen benötigen eine gezielte Neubewertung und Freigabe. Routineänderungen DÜRFEN innerhalb vorab freigegebener Änderungsprofile mit angemessenen Kontrollen erfolgen.

Begründung

KI-Verhalten entsteht aus der gesamten Kette. Eine scheinbar kleine Komponentenänderung kann Qualität, Sicherheit oder Berechtigungswirkung verschieben.

Umsetzung im Geltungsbereich

Gewöhnliche Dokumentenpflege, Indexaktualisierung und wiederherstellbare Codearbeit erfordern keine vollständige KI-Neufreigabe. Die jeweils betroffenen Funktionen werden geprüft. Wiederherstellungswege werden risikobasiert regelmäßig und nach relevanten Änderungen erprobt; nicht jede

³² Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 29–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Measure-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Software engineering — SQuaRE — Quality model for AI systems, ISO/IEC 25059:2023, Stand ISO-Metadaten, Ausgabe 2023-06, veröffentlicht am 01.06.2023, öffentliche Metadaten zum KI-Qualitätsmodell, <https://www.iso.org/standard/80655.html>, abgerufen am 02.09.2026.

kleine Änderung verlangt einen vollständigen Rückkehrtest. Rückkehr zu früheren Ständen darf inzwischen entzogene Rechte, unzulässige Daten oder gelöschte Inhalte nicht reaktivieren.

Prüfziel

Routine- und wesentliche Änderungen anhand repräsentativer Fälle korrekt einordnen; erforderliche Prüfungen und aktuelle Rechte bei einer Wiederherstellung nachweisen.

Erwartete Nachweise

Änderungsantrag; Auswirkungsanalyse; Ergebnisse der Wiederholungsprüfungen; neues Freigabemanifest; Rückkehrplan und Rückkehrtest; Kommunikationsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Änderung; Test; Freigabe; Änderungsverantwortliche; Testverantwortliche; Betriebsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundsatz: OPS.1.1.3, OPS.1.1.6; ISO: ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 8 und S. 11–12; [Q-BMVG-001] S. 29–32 und S. 45–47; [Q-ISO-5338] öffentliche Lebenszyklusmetadaten³³

9.15 Protokollierung, Überwachung, Verhaltensänderungen, Vorfälle und Wiederanlauf

KI-OPS-001 – Datensparsame und manipulationsgeschützte KI-Protokollierung

Normative Anforderung

Sicherheitsrelevante KI-Ereignisse MÜSSEN nach dem allgemeinen Protokollierungs- und Datenschutzkonzept datensparsam erfasst und geschützt werden. Protokolle DÜRFEN nicht stillschweigend als Unternehmenswissen genutzt werden.

Begründung

Ohne technische Kontextdaten lassen sich Modellverhalten und Agentenwirkungen nicht untersuchen; vollständige Eingaben können zugleich sensible Inhalte und Geheimnisse vervielfachen.

³³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8 und S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 29–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, öffentliche Lebenszyklusmetadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

Umsetzung im Geltungsbereich

Vorhandene Protokollierungs- und Auswertungsdienste werden genutzt. Standardmäßig genügen notwendige Metadaten wie Identität, Zeitpunkt, Dienst, Entscheidung und Fehlerstatus; Inhaltsprotokollierung benötigt einen geregelten Zweck, Umfang und Zugriff. Geheimnisse werden nicht protokolliert. Persönliche Verläufe sind davon zu unterscheiden und nach KI-RAG-004 zulässig. Aufbewahrung, Auswertung und Löschung folgen bestehenden Regeln.

Prüfziel

Repräsentative Ereignisse auf Zuordnung, erforderliche Metadaten, Zugriffsschutz und unerwünschte Eingabe-, Inhalts- oder Geheimnisdaten prüfen.

Erwartete Nachweise

Protokollierungskonzept; Beispieldatensätze; Zeit- und Integritätsnachweis; Regeln der zentralen Sicherheitsauswertung; Zugriffs- und Löschprüfung; Rekonstruktionsübung.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Betrieb; Vorfall; Prüfung; Protokollierungsverantwortliche; Datenschutzbeauftragte; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.5, DER.1; ISO: ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17

Quellen

[Q-BSI-001] S. 12–13; [Q-BMVG-001] S. 23–26 und S. 45–47; [Q-DSK-002] Kap. 2–6³⁴

KI-OPS-002 – Überwachung, schleichende Verhaltensänderungen und KI-Vorfallbehandlung

Normative Anforderung

KI-Sicherheits- und Qualitätsauffälligkeiten MÜSSEN in die vorhandene Überwachung und Vorfallbehandlung eingebunden werden. Betroffene Funktionen MÜSSEN angemessen begrenzt oder abgeschaltet werden können; nicht betroffene Arbeit MUSS fortführbar bleiben.

Begründung

Verschlechterungen und Angriffe zeigen sich häufig zuerst in Messgrößen der Ausgaben oder Nutzung und nicht in klassischen Alarmmeldungen des Serverbetriebssystems.

³⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 23–26 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

Umsetzung im Geltungsbereich

Verfügbare Betriebs- und Qualitätsindikatoren werden im bestehenden Prozess ausgewertet. Bei Vorfällen gelten die Unternehmenswege für Meldung, Zuständigkeit, Eindämmung und Wiederfreigabe. Hohe Restrisiken und Ausnahmen folgen KI-GOV-003; die Arbeit ohne KI folgt KI-GOV-002. Ein gesonderter KI-Notfallstab ist nicht erforderlich.

Prüfziel

Künstliche Abweichungen müssen erkannt, richtig priorisiert und bis zu Eindämmung, Beweissicherung, Wiederherstellung und Nachbereitung bearbeitet werden.

Erwartete Nachweise

Überwachungskonzept; Übersichten; Alarmregeln; Bericht zu Verhaltensänderungen; Vorfalleitfäden; Übungsprotokolle; Korrektur- und Rückkehrynachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Betrieb; Vorfall; Änderung; Betriebsverantwortliche; Informationssicherheitsbeauftragte; Vorfallverantwortliche; Modellverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: DER.1, DER.2.1; ISO: ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24

Quellen

[Q-BMVG-001] S. 31–32 und S. 45–47; [Q-BSI-001] S. 8 und S. 12–16; [Q-NIST-001] Measure- und Manage-Aktionen³⁵

KI-OPS-003 – Reguläre Reparatur und konsistente Wiederherstellung

Normative Anforderung

KI-Konfigurationen und erforderliche Daten MÜSSEN nach dem bestehenden Datensicherungs-, Reparatur- und Änderungsprozess wiederherstellbar sein. Die Wiederaufnahme MUSS aktuelle Berechtigungen, Sperren und Löschstände wahren. Die Weiterarbeit ohne KI DARF nicht von einem Reparaturtermin abhängig sein.

Begründung

Ein technisch gestarteter Dienst ist nicht betriebsfähig, wenn Modell, Index, Berechtigungen oder Freigabestand auseinanderfallen.

³⁵ Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 31–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8 und S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

Umsetzung im Geltungsbereich

Der normale IT-Betrieb stellt die KI-Zugänglichkeit nach Fehlerbehebung wieder her und prüft relevante Zugangs- und Kernfunktionen. Ein gültiger Ersatzschlüssel kann einen Fehler der Authentisierung bei einem bereits freigegebenen Dienst beheben, nicht einen Anbieterausfall. Ein gleich eingerichteter Ersatzserver oder ein anderes freigegebenes Modell kann genutzt werden, ist aber nicht verpflichtend. Ein eigenes KI-Notfallkonzept, verpflichtende Doppelhardware oder eine besondere KI-Wiederanlaufzeit wird nicht verlangt. Bei längerem Ausfall bleibt die Arbeit ohne KI möglich.

Prüfziel

Den vorgesehenen Reparaturweg und eine repräsentative Wiederherstellung einschließlich aktueller Zugriffs- und Löschstände prüfen; die Arbeit muss währenddessen ohne KI fortgesetzt werden können.

Erwartete Nachweise

Verweise auf Datensicherungs- und Reparaturverfahren; gesicherte Konfigurationen und notwendige Daten; Wiederherstellungsprüfung; Nachweise aktueller Rechte und unabhängiger Weiterarbeit.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Betrieb; Notfall; Wiederanlauf; Backup-Verantwortliche; Betriebsverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.3, DER.4; ISO: ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30

Quellen

[Q-BSI-001] S. 11–13; [Q-NCSC-001] Secure operation and maintenance; [Q-BMVG-001] S. 45–47³⁶

9.16 Außerbetriebnahme und nachweisbare Löschung

KI-DEC-001 – Kontrollierte Außerbetriebnahme

Normative Anforderung

Bei Außerbetriebnahme MÜSSEN KI-Zugänge, Geheimnisse, automatisierte Aufgaben und Daten nach den bestehenden Unternehmensprozessen behandelt werden. Nicht mehr zulässige Erreichbarkeit und Nutzung MÜSSEN beendet werden; erforderliche Aufbewahrung und Löschung MÜSSEN auch Ableitungen berücksichtigen.

³⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure operation and maintenance, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

Begründung

Verwaiste Endpunkte, Konten, Indizes, Zwischenspeicher oder Modellkopien bleiben sonst erreichbar und entziehen sich Aktualisierungs-, Rechte- und Löschprozessen.

Umsetzung im Geltungsbereich

Betrieb, Identitätsverwaltung und Datenverantwortliche entziehen Zugriffe, beenden Aufgaben und behandeln Modelle, Quelldaten, Extrakte, Indizes und Zwischenspeicher. Erforderliche Nachweise und Sicherungen bleiben nach festgelegten Fristen geschützt, ohne regulären Suchzugriff. Abschließende Stichproben prüfen verbleibende Zugänge und fristgerechte Datenbehandlung.

Prüfziel

Für eine Testaußerbetriebnahme nachweisen, dass keine aktive Erreichbarkeit oder unzulässige Datenkopie verbleibt und erforderliche Nachweise erhalten sind.

Erwartete Nachweise

Außerbetriebnahmeauftrag; Widerrufs- und Netztest; Löschprotokolle; Registerabgleich; Sicherungsbehandlung; Abschlussfreigabe.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Außerbetriebnahme; Löschung; Systemverantwortliche; Datenverantwortliche; Identitätsverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, OPS.1.1.2; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11

Quellen

[Q-BSI-001] S. 13; [Q-DSK-001] Beendigung; [Q-BMVG-001] S. 45–47³⁷

9.17 Bedingte Anforderungen für externe Inferenz

KI-EXT-001 – Neue Bewertung vor externer Inferenz

Normative Anforderung

Externe KI-Verarbeitung MUSS zusätzlich zu allgemeinen Internet- und Dienstfreigaben ausdrücklich für Modelle beziehungsweise Dienste, Zwecke, Datenarten und Empfängerkreise freigegeben sein. Ohne diese Freigabe bleibt externe Inferenz deaktiviert.

³⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, Stand 06.05.2024, Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

Begründung

Eingaben, Systemanweisungen, Kontexte, RAG-Ausschnitte, Dateiübernahmen, Metadaten und Ausgaben werden beim externen Betreiber verarbeitet; Transportverschlüsselung beseitigt diese Verarbeitung nicht.

Umsetzung im Geltungsbereich

Die zuständigen Stellen nutzen die bestehenden Anbieter-, Vertrags-, Datenschutz- und IT-Sicherheitsprozesse und ergänzen KI-spezifische Datenflüsse. Das Nutzungsprofil erfasst Eingaben, Dateien, Wissensausschnitte und Ausgaben einschließlich Speicherung, Protokollierung, Aufbewahrung, Löschung und einer etwaigen Verwendung beim Anbieter. Nicht zugelassene Trainings- oder Weiterverwendungszwecke werden ausgeschlossen. Eine gültige Profilvergabe deckt gleichartige Anfragen ab; wesentliche Änderungen verlangen Neubewertung. Allgemeiner Internetzugang, ein API-Schlüssel oder eine IdP-Freigabe allein genügen nicht.

Prüfziel

Freigegebene Zwecke und Datenpfade mit der tatsächlichen Konfiguration vergleichen; unzulässige Datenarten und nicht freigegebene Dienste müssen außerhalb des Profils bleiben.

Erwartete Nachweise

Neue Risiko- und Datenschutzbewertung; Datenflussmodell; Verträge; Anbieterprüfung; Schlüssel- und Löschkonzept; Freigabe; negative Datentests.

Steuermerkmal	Ausprägung
Anwendbarkeit	Externe Inferenz
Lebenszyklus und Rollen	Planung; Beschaffung; Freigabe; Betrieb; Leitung; Datenschutzbeauftragte; Informationssicherheitsbeauftragte; Rechtsstelle; Beschaffung
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.2.2, CON.2; ISO: ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10

Quellen

[Q-BMI-001] S. 25–29; [Q-BSI-001] S. 4–5 und S. 9–12; [Q-BFDI-001] Kap. 1–7; [Q-EU-001] Art. 26–27³⁸

³⁸ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 4–5 und S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 1–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 26–27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

KI-EXT-002 – Freigegebene Ausweichziele und gesperrte Umgehungswege

Normative Anforderung

Ein automatischer Wechsel auf eine nicht freigegebene KI-Umgebung MUSS verhindert werden. Zusätzliche Modelle DÜRFEN als Ausweichziele konfiguriert werden, wenn sie bereits für Zweck, Daten und Schutzbedingungen freigegeben sind. Dies gilt für lokale und externe Ziele; externe KI benötigt KI-EXT-001.

Begründung

Automatische Ausweichverbindungen können bei Fehlern oder Kapazitätsengpässen gerade dann Daten extern übertragen, wenn reguläre Kontrollen nicht aufmerksam beobachtet werden.

Umsetzung im Geltungsbereich

Ausweichprofile nennen die zulässigen Ziele und gegebenenfalls den erlaubten automatischen Wechsel. Eine bloße Internetfreigabe genügt nicht. Ohne solches Profil erfolgt kein automatischer Zielwechsel; die normale Arbeit wird ohne KI fortgeführt. Ersatzmodelle und Cloud-Ausweichziele sind optional. Anbietererkennung, Fehlerpfade und Erweiterungen werden auf unbeabsichtigte Zielwechsel geprüft.

Prüfziel

Ausfall und Anmeldefehler simulieren: Nur konfigurierte, bereits freigegebene Ausweichziele dürfen angesprochen werden. Ohne Profil bleibt der Wechsel aus; die Weiterarbeit ohne KI bleibt möglich.

Erwartete Nachweise

Anbieter- und Endpunktliste; Regeln für ausgehenden Netzwerkverkehr; freigegebener Clientausgangsstand; Ausfall- und Ausweichbindungstests; DNS-/Proxyprotokolle; Alarmnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Einführung; Test; Betrieb; Clientverantwortliche; Verantwortliche für den KI-Zugang; Netzverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, APP.6; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26

Quellen

[Q-CLINE-001] Providerkonfiguration; [Q-OPENCODE-001] Provider und lokale Modelle; [Q-BSI-001] S. 9–12³⁹

³⁹ Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, Providerkonfiguration, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Provider und lokale Modelle, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

9.18 Nachweise, Ausnahmen und akzeptierte Restrisiken

KI-ASS-001 – Prüfbare Nachweiskette und befristete Abweichungen

Normative Anforderung

Anforderungen, Risiken, Maßnahmen, Nachweise und Entscheidungen MÜSSEN über stabile Kennungen und aktuelle Fundstellen auffindbar und miteinander verknüpft sein. Änderungen MÜSSEN die zugehörigen Indizes und Verweise aktualisieren. Umsetzungsstand und Annahmen DÜRFEN nicht als bereits geprüfte Wirksamkeit dargestellt werden.

Begründung

Eine dokumentierte Anforderung ist ohne aktuellen Wirksamkeitsnachweis nicht prüfbar. Unklare Ausnahmen können dauerhaft und unsichtbar werden.

Umsetzung im Geltungsbereich

Vorhandene Dokumentations- und Nachweissysteme werden genutzt. Ein Inhaltsindex oder eine gleichwertige Navigation führt Menschen und KI-Agenten zur maßgeblichen Fassung, Kontroll-ID, Risikobewertung und Nachweisfundstelle. Zuständigkeit, Prüfergebnis, Status und Abweichungen bleiben nachvollziehbar. Die allgemeinen Referenzbewertungen setzen die beschriebene Umsetzung voraus; bei passender Umgebung können sie begründet übernommen werden. Abweichende Annahmen erfordern eine angepasste Bewertung. Risikoakzeptanz und Fristen folgen KI-GOV-003; fehlende Maßnahmen werden gesondert behandelt.

Prüfziel

Von ausgewählten Kontroll- und Risiko-IDs zur aktuellen Anforderung, Maßnahme, Quelle und Entscheidung navigieren; falsche Verweise und unzutreffende Wirksamkeitsbehauptungen ausschließen.

Erwartete Nachweise

Aktueller Inhaltsindex; stabile Kontroll- und Risiko-IDs; verknüpfte Nachweisfundstellen, Umsetzungsstände, Entscheidungen und Änderungshistorie.

Steuermerkmal	Ausprägung
Anwendbarkeit	Alle KI-Nutzungen
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; Kontrollverantwortliche; Prüfende; Risikoverantwortliche; Leitung
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, DER.3.1; ISO: ISO/IEC 27001:2022 7.5, ISO/IEC 27001:2022 9.1, ISO/IEC 42001:2023 9.1

Quellen

[Q-BSI-001] S. 8–13; [Q-BMVG-001] S. 25–32 und S. 45–47; [Q-NIST-001] Govern-, Measure- und Manage-Aktionen⁴⁰

⁴⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 25–32 und S. 45–47,

10 Wissenssuche, persönliche Speicherung und Beiträge

Dokumente unterliegen den normalen Qualitäts-, Konfigurations- und Freigabeprozessen. Die Freigabe eines Datenbereichs für KI-Wissensarbeit kann seine Dokumente umfassen; technische Lesbarkeit allein genügt nicht. Freigegebene Inhalte werden unter Wahrung von Zweck, Herkunft und Rechten aufbereitet. Persönliche Dateien, Ergebnisse und Verläufe dürfen auf verwalteten Endgeräten und in persönlichen Arbeitsbereichen nach den normalen Regeln gespeichert werden.

Unternehmenswissen aus persönlicher Agentenarbeit ist eine optionale, standardmäßig ausgeschaltete Funktion. Bei der ersten Nutzung und bei jedem neuen Agentenprojekt wird nach verständlicher Information über Umfang, Zweck, Ziel, Empfänger und die Behandlung bestehender Beiträge eine ausdrückliche Entscheidung eingeholt. Erstnutzung und erstes Projekt können gemeinsam abgefragt werden. Ablehnung lässt die gewöhnliche KI-Arbeit unverändert möglich; gewöhnliche Chatbot-Dialoge werden nicht automatisch übernommen.

Bei aktiver Übernahme bleiben Zustand und Umfang sichtbar. Neue Beiträge können jederzeit gestoppt werden. Bestehende Beiträge bleiben nach den vorher erläuterten Nutzungs- und Aufbewahrungsregeln behandelt; ein Stopp löst keine automatische Bestandslöschung aus. Entfällt eine Berechtigung oder zulässige Nutzung, wird der Zugriff unabhängig davon gesperrt. Ohne verlässliche Zustimmung, sichtbaren Status und Rechteübernahme bleibt die optionale Beitragsfunktion aus.

<https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Govern-, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

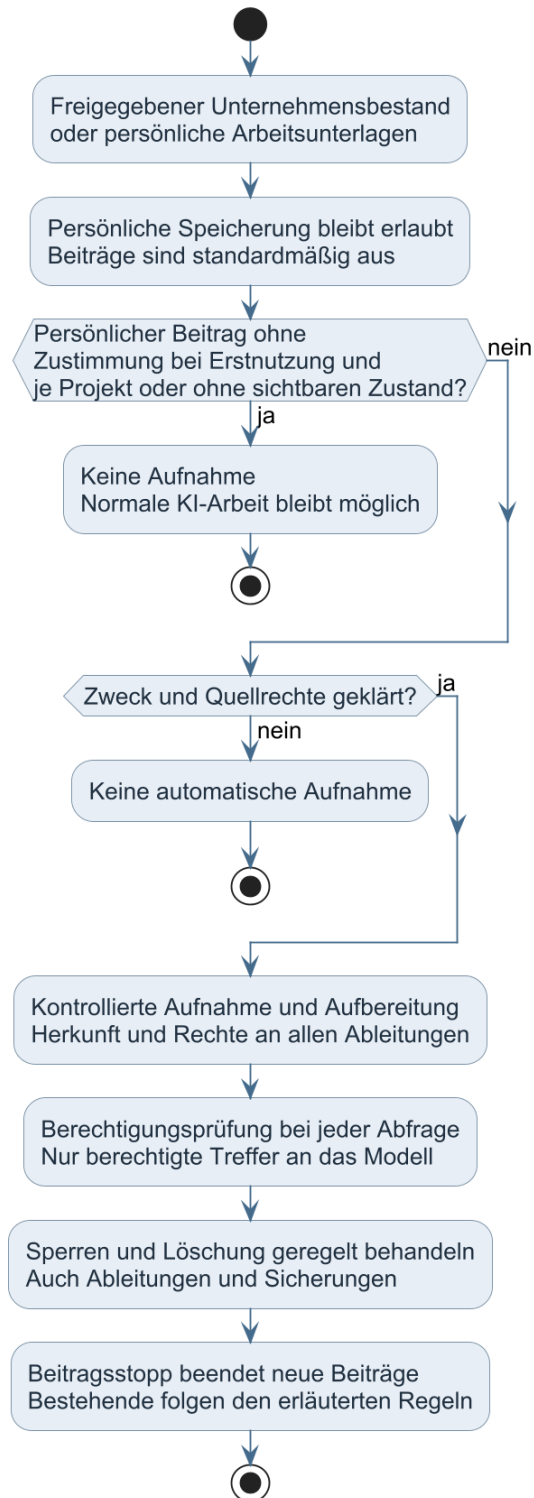


Abbildung 5: Freigegebene Bestände und freiwillige Beiträge wahren Zweck, Rechte und geregelte Datenbehandlung.

- Suchvektoren, Textabschnitte, Indizes, Zwischenspeicher und Daten zur Neusortierung erhalten mindestens den Schutzbedarf der Quelldaten.
- Das Sprachmodell und Systemanweisungen treffen keine Zugriffsentscheidung.
- Eine Zustimmung erweitert keine Rechte: geschützte Personal- oder Kundendaten werden auch über Zusammenfassungen keinem größeren Empfängerkreis zugänglich.

- Ausgaben weisen verwendete Quellen und konkrete Fundstellen nachvollziehbar aus.
- Löschung umfasst Onlinekopien, Ableitungen, Zwischenspeicher und den geregelten Ablauf in Sicherungsketten.

RAG-Indexierung und Wissensbeiträge ändern keine Modellgewichte. Training und Feinabstimmung bleiben ausgeschlossen. Das Abrufen vorhandenen Wissens ist keine Erlaubnis, neue Interaktionen in den Bestand zu schreiben. Eine Modellzusammenfassung belegt keine sichere Anonymisierung; unklare Rechte oder Zwecke verhindern automatische Aufnahme.

11 Agentische Anwendungen und lokale Entwicklungsumgebungen

Agentische Clients nutzen freigegebene Modelle, Entwicklungsdienste und Arbeitsbereiche. Codebearbeitung, Analyse, Tests, Lesen und Erzeugen von Dateien können im genehmigten Aufgaben- und Berechtigungsumfang selbstständig erfolgen. Vorhandene Unternehmensanmeldung, Qualitätssicherung und Konfigurationsverwaltung gelten auch hier.

Werkzeugprofile und wirksame Zugriffsgrenzen prüfen Modellvorschläge unabhängig vom Modell. Löschungen und andere destruktive Aktionen benötigen nur dann keine Einzelgenehmigung, wenn der Nutzer Änderungen und maßgebliche Folgen schnell, einfach und zuverlässig rückgängig machen kann und kein erheblicher Schaden zu erwarten ist. Fehlt diese Möglichkeit, wird jede Löschung und destruktive Tätigkeit konkret genehmigt. Kritische, privilegierte und nicht rückgängig zu machende Wirkungen bleiben genehmigungspflichtig (Abbildung 6).

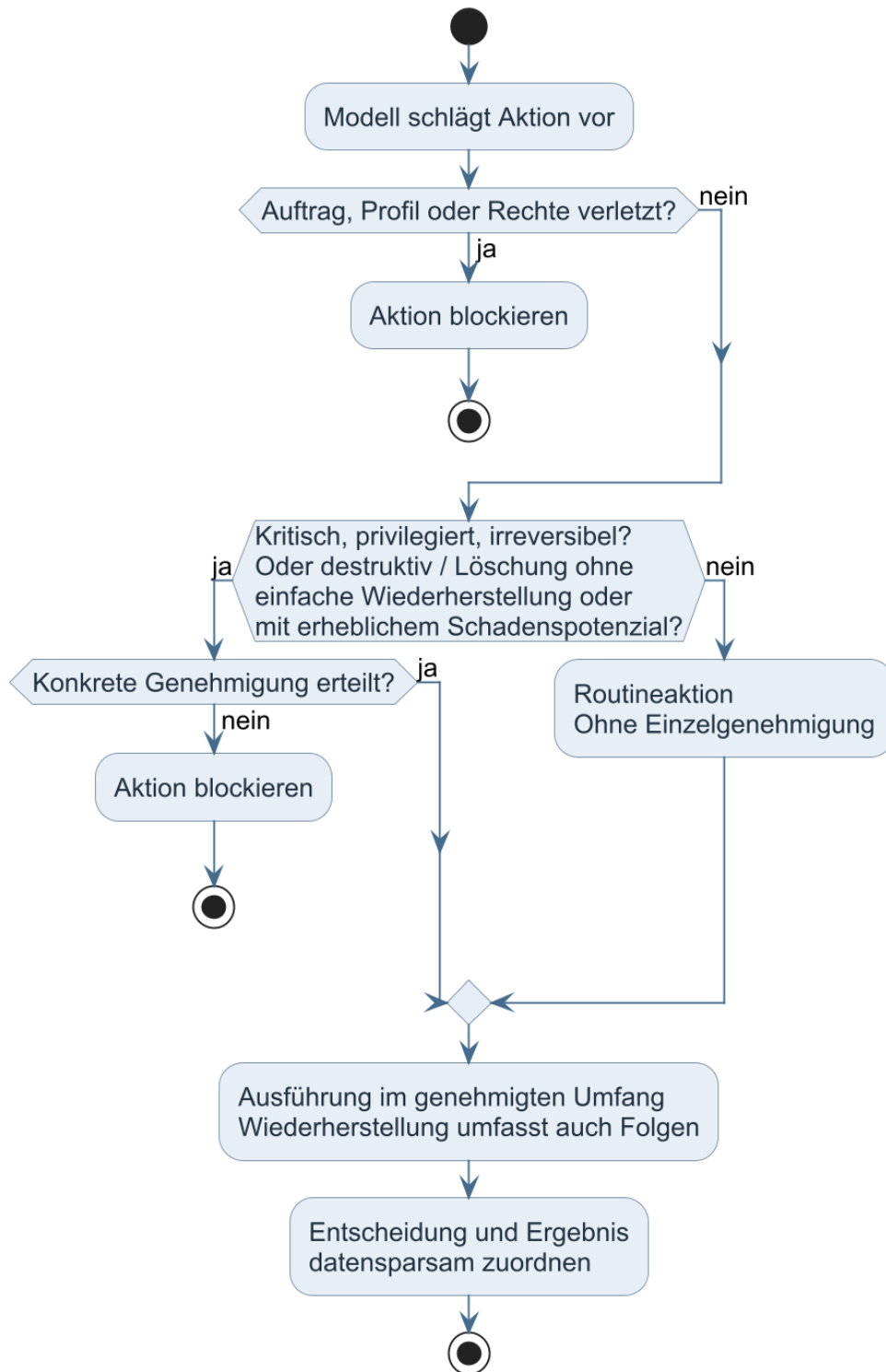


Abbildung 6: Routineaktionen folgen dem Arbeitsprofil; nicht beherrschbare Wirkungen benötigen konkrete Genehmigung.

- Arbeitsbereichs- und Dateirechte sind minimal und überschreiten weder Projekt noch genehmigten Zweck.
- Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff sind getrennte Fähigkeiten.
- Versionierung oder Wiederherstellungspunkte müssen praktisch nutzbar sein und die betroffenen Daten und Folgen abdecken.

- Eingeschleuste Anweisungen aus Quellcode, Dokumenten, Webseiten und Werkzeugausgaben dürfen keine Rechte erweitern.
- Übertragungen in freigegebene Codeablagen können zum Routineprofil gehören; das Zurücksetzen von Code macht eine Offenlegung oder bereits ausgelöste Veröffentlichung nicht rückgängig.
- Erweiterungen und Werkzeugprotokolle folgen dem bestehenden Software- und Sicherheitsprozess.

12 Betrieb, Änderung, Modellwechsel, Vorfälle und Außerbetriebnahme

Betrieb, datensparsame Protokollierung, Überwachung, Datensicherung und Vorfallbehandlung folgen dem allgemeinen IT-Sicherheitskonzept. Routineänderungen verwenden vorab freigegebene Änderungsprofile; wesentliche Änderungen an Modellen, Rechten, Datenflüssen oder Sicherheitsfunktionen erhalten eine gezielte Neubewertung. Wiederholte Qualitätsbewertungen berücksichtigen die Streuung von Modellausgaben. Verfügbare Modell- und Anbieterstände sowie Grenzen ihrer Fixierbarkeit werden dokumentiert.

Alle Tätigkeiten bleiben auch bei längerem KI-Ausfall ohne KI möglich. Benötigte Daten, Zugänge, Anwendungen und Kenntnisse sind unabhängig verfügbar; geringere Geschwindigkeit oder Qualität bleibt innerhalb der geltenden Mindestanforderungen zulässig. Ressourcenisolation verhindert, dass KI-Überlastung die übrige IT blockiert. Reparatur und Wiederaufnahme erfolgen im normalen IT-Betrieb, ohne dass die Weiterarbeit auf einen Reparaturtermin wartet.

Ein Ersatzschlüssel für einen bereits freigegebenen Dienst kann einen Anmeldefehler beheben, nicht dessen Anbieterausfall. Ein gleich eingerichteter Ersatzserver oder ein freigegebenes Ersatzmodell kann genutzt werden. Ein eigenes KI-Notfallkonzept, verpflichtende Doppelhardware oder eine besondere KI-Wiederanlaufzeit wird nicht verlangt. Wiederherstellung bewahrt aktuelle Rechte, Sperren und Löschstände.

Automatische Zielwechsel sind nur innerhalb bereits freigegebener Ausweichprofile erlaubt. Weitere lokale Modelle oder ausdrücklich freigegebene externe KI können darin enthalten sein. Allgemeine Internetnutzung ist keine zusätzliche KI-Freigabe. Ohne zulässiges Ziel erfolgt die Weiterarbeit ohne KI; Ausweichmodelle sind optional.

Bei Außerbetriebnahme werden Identitäten, Zertifikate, Geheimnisse, Endpunkte, automatisierte Aufgaben, Modelle, Daten, Indizes und Zwischenspeicher behandelt. Erforderliche Prüfnachweise bleiben entsprechend der Aufbewahrungsfrist erhalten; unzulässige Restkopien und Erreichbarkeit müssen durch Nachtests ausgeschlossen werden.

13 Nachweis-, Prüf- und Zuordnungsübersicht

Für jede anwendbare Kontrolle werden Umsetzung, verantwortliche Rolle, Prüfergebnis, Nachweisfundstelle, Abweichung und Restrisiko nachvollziehbar geführt. Die Zuordnungen unterstützen die gemeinsame Prüfung mit dem allgemeinen Informationssicherheitsmanagement.

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-GEL-001	Abgrenzung zum allgemeinen IT-Sicherheitskonzept	Alle KI-Nutzungen	ISMS.1, ORP.1	ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1
KI-GEL-002	Schutzkennzeichnung und kontrollierte Dokumentenführung	Alle KI-Nutzungen	ORP.1, CON.10	ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12
KI-GOV-001	KI-Inventar und eindeutige Verantwortung	Alle KI-Nutzungen	ORP.1, OPS.1.1.2	ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3
KI-GOV-002	Genehmigte Nutzung und KI-Kompetenz	Alle KI-Nutzungen	ORP.3, ORP.4	ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3
KI-GOV-003	Lebenszyklus-Risikosteuerung, Ausnahmen und Überprüfungen	Alle KI-Nutzungen	ISMS.1, OPS.1.1.3	ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023
KI-REC-001	Rechts- und Datenschutzprüfung je Anwendungsfall	Alle KI-Nutzungen	ORP.5, CON.2	ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2
KI-REC-002	Schutzbedarf und Geheimhaltungsfreigabe	Alle KI-Nutzungen	CON.10, ORP.4	ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13
KI-ARC-001	Explizite Zonen und einziger kontrollierter KI-Zugang	Alle KI-Nutzungen	NET.1.1, NET.3.2	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22
KI-ARC-002	Unternehmensintegration und freigegebene Datenflüsse	Alle KI-Nutzungen	NET.1.1, OPS.1.1.10	ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20
KI-CON-001	Standardmäßig verweigerter Containerkommunikation	Containerbetrieb	APP.3.4, SYS.1.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-CON-002	Minimale Containerprivilegien und unveränderbare Laufzeit	Containerbetrieb	SYS.1.6, OPS.1.1.2	ISO/IEC 27002:2022 8.9, ISO/IEC 27002:2022 8.27
KI-API-001	Unternehmensanmeldung und kontrollierter KI-Zugang	Alle KI-Nutzungen	ORP.4, APP.6, CON.1	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5
KI-API-002	Serverseitige Modell-, Kontext-, Anfrage- und Werkzeuggrenzen	Alle KI-Nutzungen	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-MOD-001	Kontrollierter Modellimport und Herkunftsnachweis	Lokale Artefakte	OPS.1.1.10, OPS.1.1.6	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19
KI-MOD-002	Versionierte Modellfreigabe und Rückkehr zur Vorversion	Alle KI-Nutzungen	OPS.1.1.3, OPS.1.1.6	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-TRN-001	Keine Änderung von Modellgewichten	Alle KI-Nutzungen	APP.6, OPS.1.1.3	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-RAG-001	Kontrollierte Aufnahme und isolierte Dokumentenaufbereitung	Dateiaufnahme	APP.6, SYS.1.6	ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26
KI-RAG-002	Durchgängige Berechtigungsprüfung und Indextrennung	Wissenssuche	ORP.4, APP.6	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3
KI-RAG-003	Schutz, Herkunft, Aufbewahrung und Löschung abgeleiteter Daten	Abgeleitete Daten	CON.6, CON.3	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024
KI-RAG-004	Persönliche Speicherung und freiwillige Wissensbeiträge	Persönliche Daten	CON.6, APP.6	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-IAM-001	Minimalrechte und Umgang mit Zugangsdaten und Geheimnissen für KI-Dienste	Alle KI-Nutzungen	ORP.4, CON.7	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2
KI-AGT-001	Genehmigte Arbeitsbereiche und wirksame Zugriffsgrenzen	Agenten	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-AGT-002	Freigegebene KI-Ziele für agentische Anwendungen	Agenten	APP.6, NET.1.1	ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20
KI-PMT-001	Nicht vertrauenswürdige Inhalte und eingeschleuste Anweisungen	Alle KI-Nutzungen	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-OUT-001	Prüfung, Kennzeichnung und menschliche Freigabe von Ausgaben	Alle KI-Nutzungen	APP.6, OPS.1.1.6	ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023
KI-TOL-001	Getrennte Werkzeugfunktionen und Bestätigung kritischer Aktionen	Werkzeuge	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-TOL-002	Kontrollierte Erweiterungen, MCP-Server und Werkzeugprotokollierung	Erweiterungen	OPS.1.1.10, OPS.1.1.5	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15
KI-THR-001	KI-spezifisches Bedrohungsmodell	Alle KI-Nutzungen	DER.1, APP.6	ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023
KI-THR-002	Ressourcen-, Missbrauchs- und Verfügbarkeitsgrenzen	Alle KI-Nutzungen	OPS.1.1.1, DER.1	ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16
KI-VAL-001	Wiederholbare Qualitäts- und Sicherheitsbewertung	Alle KI-Nutzungen	OPS.1.1.6, APP.6	ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023
KI-VAL-002	Änderungsabhängige Wiederholungsprüfung, Wiederfreigabe und Rückkehr zur Vorversion	Alle KI-Nutzungen	OPS.1.1.3, OPS.1.1.6	ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-OPS-001	Datensparsame und manipulationsgeschützte KI-Protokollierung	Alle KI-Nutzungen	OPS.1.1.5, DER.1	ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17
KI-OPS-002	Überwachung, schleichen- de Verhaltensänderungen und KI-Vorfallbehandlung	Alle KI-Nutzungen	DER.1, DER.2.1	ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24
KI-OPS-003	Reguläre Reparatur und konsistente Wiederherstel- lung	Alle KI-Nutzungen	CON.3, DER.4	ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30
KI-DEC-001	Kontrollierte Außerbe- triebnahme	Alle KI-Nutzungen	CON.6, OPS.1.1.2	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11
KI-EXT-001	Neue Bewertung vor ex- terner Inferenz	Externe Inferenz	OPS.2.2, CON.2	ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10
KI-EXT-002	Freigegebene Ausweichzie- le und gesperrte Umge- hungswege	Alle KI-Nutzungen	NET.1.1, APP.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26
KI-ASS-001	Prüfbare Nachweiskette und befristete Abweichun- gen	Alle KI-Nutzungen	ISMS.1, DER.3.1	ISO/IEC 27001:2022 7.5, ISO/IEC 27001:2022 9.1, ISO/IEC 42001:2023 9.1

14 Quellenverzeichnis und Abkürzungen

14.1 Quellenverzeichnis

[Q-BMI-001] Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29; S. 30,
<https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

[Q-BSI-001] Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 4–7; S. 8–10; S. 11–13; S. 14–16,
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

[Q-BSI-2002-001] Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschutz-Methodik, Version 1.0, Stand Oktober 2017, S. 11 und S. 69–74; S. 154–156,
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_2.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

[Q-BSI-2003-001] Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7; S. 26–28; S. 33–35,
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

[Q-BMVG-001] Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 23–26; S. 28–34; S. 45–50,
<https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

[Q-BSI-SDT-001] Bundesamt für Sicherheit in der Informationstechnik: Stand-der-Technik-Bibliothek, Commit 8a97764ff4f23c2b7945c64344eecbf5a2053db2, Commit vom 27.08.2026, Repository-Inhalt und OSCAL-Katalog am fixierten Commit, <https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/commit/8a97764ff4f23c2b7945c64344eecbf5a2053db2>, abgerufen am 02.09.2026.

[Q-NIST-OSCAL-001] National Institute of Standards and Technology: OSCAL Version 1.1.3 – Catalog JSON Schema, OSCAL 1.1.3, Stand Release vom 26.11.2024, Gesamtes Catalog-JSON-Schema, https://github.com/usnistgov/OSCAL/releases/download/v1.1.3/oscal_catalog_schema.json, abgerufen am 02.09.2026.

[Q-EU-001] Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 2–4; Art. 9–15; Art. 26 und 27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

[Q-BFDI-001] Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand

22.12.2025, Kap. 1–3; Kap. 4–7,

https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

[Q-DSK-001] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, Stand 06.05.2024, Gesamtdokument, insbesondere Auswahl, Einführung, Nutzung und Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026.

[Q-DSK-002] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

[Q-DSK-003] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026.

[Q-NIST-001] National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Profile actions for Govern, Map, Measure and Manage, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

[Q-NIST-002] National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, Stand Finalfassung 2025, veröffentlicht am 24.03.2025, Taxonomie der Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026.

[Q-ENISA-001] European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, Stand 2023, veröffentlicht am 15.11.2023, Multilayer framework und good practices, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

[Q-NCSC-001] UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure design, development, deployment, operation and maintenance, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026.

[Q-OWASP-001] OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, LLM Top 10 2025, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

[Q-MITRE-001] The MITRE Corporation: MITRE ATLAS, Laufend gepflegte Wissensbasis, Abrufstand 02.09.2026, Tactics and techniques, <https://atlas.mitre.org/>, abgerufen am 02.09.2026.

[Q-K8S-001] The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1, Online-Dokumentation, Abrufstand 02.09.2026, NetworkPolicySpec, ingress und egress, <https://kubernetes.io/docs/reference/kubernetes-api/networking/network-policy-v1/>, abgerufen am 02.09.2026.

[Q-DOCKER-001] Docker, Inc.: Rootless mode, Online-Dokumentation, Abrufstand 02.09.2026, Rootless mode, <https://docs.docker.com/engine/security/rootless/>, abgerufen am 02.09.2026.

[Q-PODMAN-001] Podman Project: podman-network, Online-Dokumentation, Abrufstand 02.09.2026, Network management und network create, <https://docs.podman.io/en/latest/markdown/podman-network.1.html>, abgerufen am 02.09.2026.

[Q-OLLAMA-001] Ollama: Authentication, Online-Dokumentation, Abrufstand 02.09.2026, Local access, <https://docs.ollama.com/api/authentication>, abgerufen am 02.09.2026.

[Q-VLLM-001] vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026.

[Q-OPENWEBUI-001] Open WebUI: Starting with OpenAI-compatible providers, Online-Dokumentation, Abrufstand 02.09.2026, Connection to OpenAI-compatible providers, <https://docs.openwebui.com/getting-started/quick-start/connect-a-provider/starting-with-openai-compatible/>, abgerufen am 02.09.2026.

[Q-OPENWEBUI-002] Open WebUI: API Endpoints, Online-Dokumentation, Abrufstand 02.09.2026, Authentication und API endpoints, <https://docs.openwebui.com/reference/api-endpoints/>, abgerufen am 02.09.2026.

[Q-CLINE-001] Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, OpenAI-Compatible Providers, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026.

[Q-OPENCODE-001] Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Local models und provider configuration, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026.

[Q-LLAMACPP-001] ggml-org: llama.cpp, Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee, Stand README-Stand 23.08.2026, README und llama-server-Verweise, <https://github.com/ggml-org/llama.cpp/tree/ccc8fd2baa64ab26c7210b02765d3604069ec7ee>, abgerufen am 02.09.2026.

[Q-DAKKS-001] Deutsche Akkreditierungsstelle GmbH: Was ist Akkreditierung?, Online-Information, Abrufstand 02.09.2026, Begriffsdefinition Akkreditierung, <https://www.dakks.de/de/was-ist-akkreditierung.html>, abgerufen am 02.09.2026.

[Q-BSIG-001] Bundesrepublik Deutschland: Gesetz über das Bundesamt für Sicherheit in der Informationstechnik und über die Sicherheit in der Informationstechnik von Einrichtungen, BSIG 2025, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 02.12.2025, Anwendungsbezogen zu prüfende Vorschriften, https://www.gesetze-im-internet.de/bsig_2025/BJNR12D0B0025.html, abgerufen am 02.09.2026.

[Q-SUEG-001] Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994, § 4, https://www.gesetze-im-internet.de/s_g/___4.html, abgerufen am 02.09.2026.

[Q-VSA-001] Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023, Allgemeine Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026.

[Q-ISO-27001] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC 27001:2022, Stand ISO-Metadaten, Ausgabe 2022-10, veröffentlicht am 01.10.2022, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/27001>, abgerufen am 02.09.2026.

[Q-ISO-27002] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security controls, ISO/IEC 27002:2022, Stand ISO-Metadaten, Ausgabe 2022-02, veröffentlicht am 01.02.2022, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/75652.html>, abgerufen am 02.09.2026.

[Q-ISO-42001] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Management system, ISO/IEC 42001:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/42001>, abgerufen am 02.09.2026.

[Q-ISO-23894] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Guidance on risk management, ISO/IEC 23894:2023, Stand ISO-Metadaten, Ausgabe 2023-02, veröffentlicht am 01.02.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/77304.html>, abgerufen am 02.09.2026.

[Q-ISO-42005] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence (AI) — AI system impact assessment, ISO/IEC 42005:2025, Stand ISO-Metadaten, Ausgabe 2025-05, veröffentlicht am 01.05.2025, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/42005>, abgerufen am 02.09.2026.

[Q-ISO-5338] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

[Q-ISO-5259] International Organization for Standardization / International Electrotechnical Commission: Artificial intelligence — Data quality for analytics and machine learning (ML) — Part 1, ISO/IEC 5259-1:2024, Stand ISO-Metadaten, Ausgabe 2024-07, veröffentlicht am 01.07.2024,

Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/81088.html>, abgerufen am 02.09.2026.

[Q-ISO-25059] International Organization for Standardization / International Electrotechnical Commission: Software engineering — SQuaRE — Quality model for AI systems, ISO/IEC 25059:2023, Stand ISO-Metadaten, Ausgabe 2023-06, veröffentlicht am 01.06.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/80655.html>, abgerufen am 02.09.2026.

[Q-BSI-GSK-001] Bundesamt für Sicherheit in der Informationstechnik: IT-Grundschutz-Kompendium – öffentliche Baustein- und Anforderungskennungen, Über die Stand-der-Technik-Bibliothek fixierte Referenz, Stand Commitstand 27.08.2026, OSCAL-Katalog am fixierten Commit, <https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/tree/8a97764ff4f23c2b7945c64344eecbf5a2053db2>, abgerufen am 02.09.2026.

14.2 Abkürzungen

Abkürzung	Langform	Abkürzung	Langform
ACL	Zugriffssteuerungsliste (Access Control List)	KI	Künstliche Intelligenz
API	Programmierschnittstelle (Application Programming Interface)	MFA	Mehrfaktorauthentisierung
BfDI	Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit	MCP	Model Context Protocol
BMI	Bundesministerium des Innern	OSCAL	Open Security Controls Assessment Language
BMVg	Bundesministerium der Verteidigung	RAG	Abrufgestützte Generierung (Retrieval Augmented Generation)
BSI	Bundesamt für Sicherheit in der Informationstechnik	SIEM	Zentrale Sammlung und Auswertung von Sicherheitsereignissen (Security Information and Event Management)
DSK	Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder	TLS	Transportverschlüsselung (Transport Layer Security)
IdP	Identitätsanbieter (Identity Provider)	VPN	Virtuelles privates Netz (Virtual Private Network)
ISMS	Informationssicherheitsmanagementsystem		